Payment System Information Security & Crypto

Prof Konstantinos Markantonakis

(BSc, MSc, MBA, PhD)

Professor of Information Security

Director of the ISG Smart Card and IoT Security Centre (SCC)

K.Markantonakis@rhul.ac.uk

http://www.isg.rhul.ac.uk/~kostasm

Office: FW158, Tel: 01784-414409

Information Security Group Smart Card Centre

http://www.scc.rhul.ac.uk

ORIGINAL SLIDE DECK FROM
DAVID MAIN

Learning Objectives

- Appreciate the history and scale of a global payment system
- Understand how information security is applied to card payment systems:
  - Magnetic-stripe, Chip & PIN and e-commerce
- Be aware of the standards and specifications that underpin the payments industry
- Match security theory against practical implementation in the payment card world
- Recognise related activities such as:
  - Two factor Authentication, Contactless, Mobile, Tokenisation
- Explain how embedded systems enforce trust in payment environments
- Describe how autonomous security decisions are made offline
- Understand why EMV uses layered cryptography and key hierarchies
- Relate payment systems to broader embedded and autonomous security design

What Systems Are We Studying?

This lecture focuses on real-world embedded systems used in global payment infrastructures

Smart Card (ICC)

- Secure element with constrained CPU and memory
- Stores long-term cryptographic secrets
- Performs autonomous security decisions

Payment Terminal (POS / ATM)

- Embedded operating system
- Enforces certificates, PIN entry and transaction policy

Backend Hardware Security Modules (HSMs)

- High-assurance embedded devices used by issuers and acquirers

Key point: security emerges from the interaction of these systems, not from any single component

Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication

From Manual Payments to Global Automated Networks

- Early payment systems (1910s–1960s)
  - Charge and credit cards introduced for convenience
  - Manual authorisation and paper-based settlement
  - Slow, national, and labour-intensive processes
- Key turning point (1970s–1980s)
  - Rapid growth made manual systems impossible to scale
  - Real-time authorisation and automated settlement required
- Result: global transaction networks and embedded terminals

https://www.youtube.com/watch?v=sxpkcgWTHdI

https://www.youtube.com/watch?v=_TBD8HTssRA

Early Failures and the Birth of Risk-Based Security

- Early large-scale deployments exposed systemic weaknesses
  - High levels of unpaid debt and transaction fraud during early large-scale deployment
  - Limited controls when operating nationally and globally
- Key lesson learned
  - **Fraud cannot be eliminated, only managed**
  - **Security must be scalable and economically viable**
- Lasting impact on system design
  - **Automated decision-making and embedded risk management**
  - Foundations of modern payment security architecture

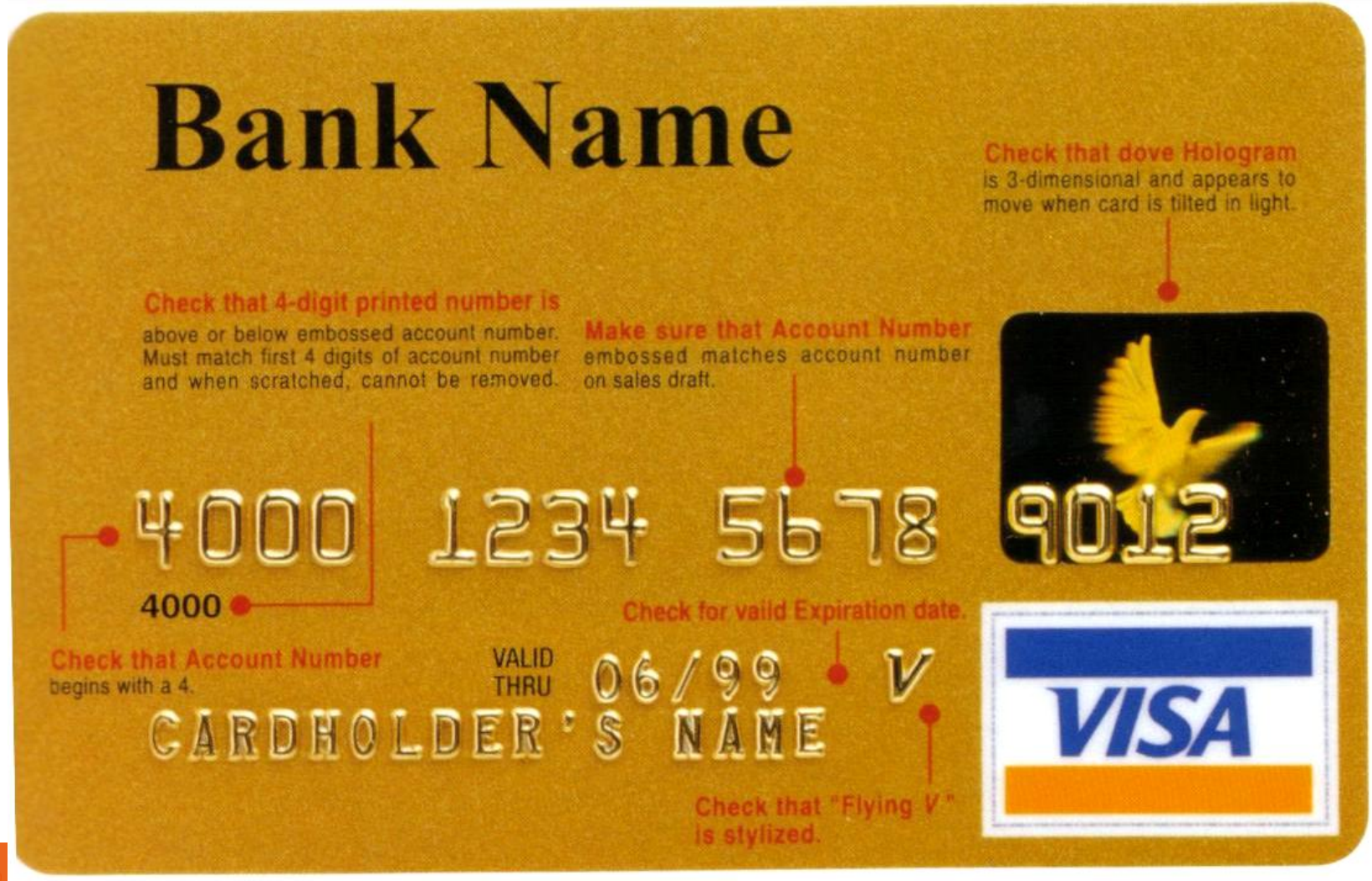
Early Security was Physical

- Initially just a card, first printed and then embossed with the ID number and cardholder details, with a space for the signature.
- Mag-stripe was added in the 1970s to allow the online electronic terminals to automatically read the data with a swipe.
- More sophisticated signature panels were needed to deter re-writing and mag-stripes needed anti-fraud features.

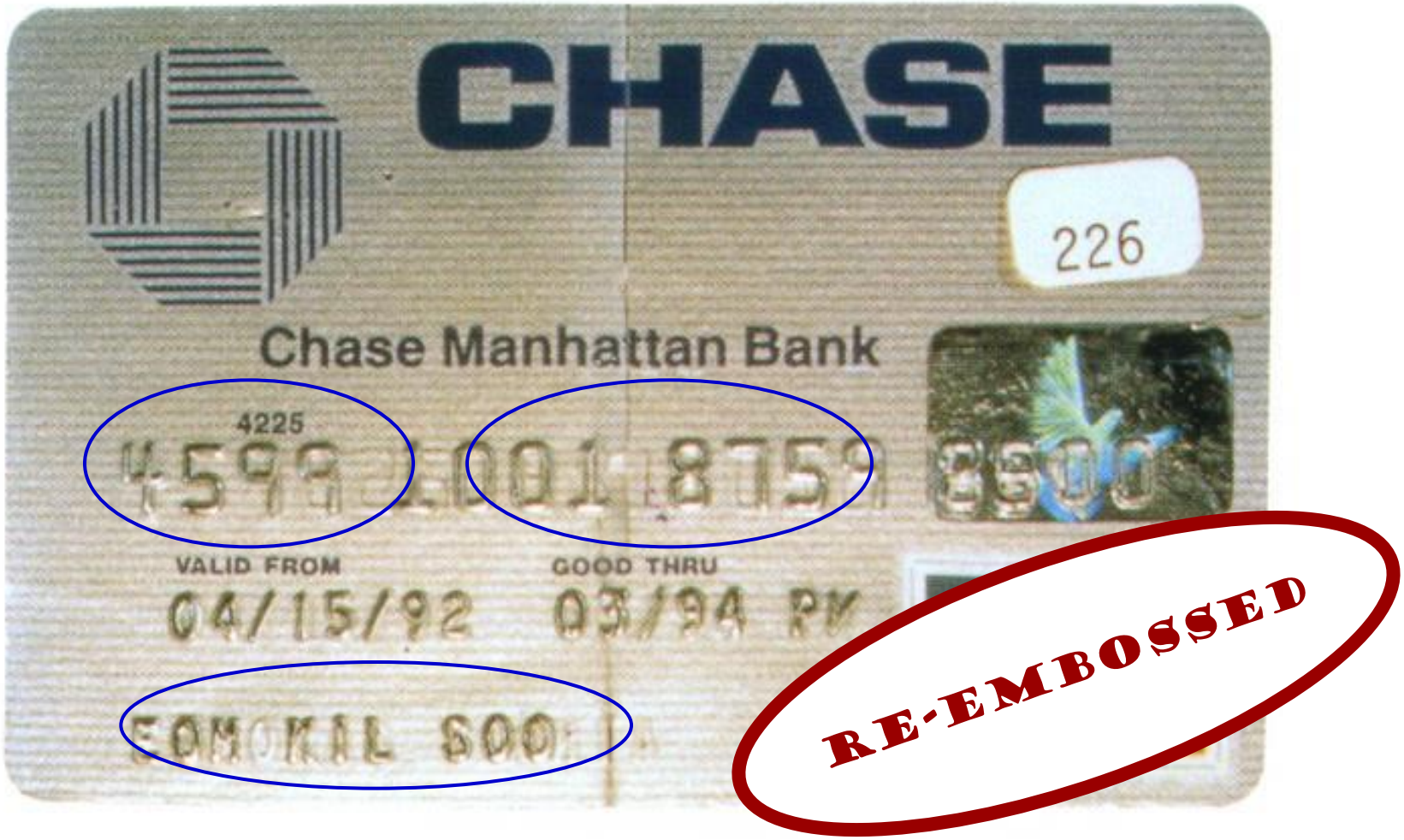
Base I, Base II and VISA NET

- BASE I (1973) - Real-time transaction authorization system.
  - Used COBOL, Assembly, PL/I, JCL on IBM Mainframes.
  - Enabled quick transaction approvals for Visa cards.
- BASE II - Batch clearing & settlement system.
  - Processed transaction data in bulk for final settlements.
  - Supported large-scale banking operations.
- VisaNet (Modern Era) - Replaced BASE I & II
  - Uses Java, C++, Python, Go, Kotlin.
  - Cloud-based, high-speed, AI-driven fraud detection.
  - Handles 65,000+ transactions per second globally.
- VisaNet is now one of the most advanced transaction networks worldwide.

Early Security was Physical



Physical Security Features



Physical Security Features

Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication

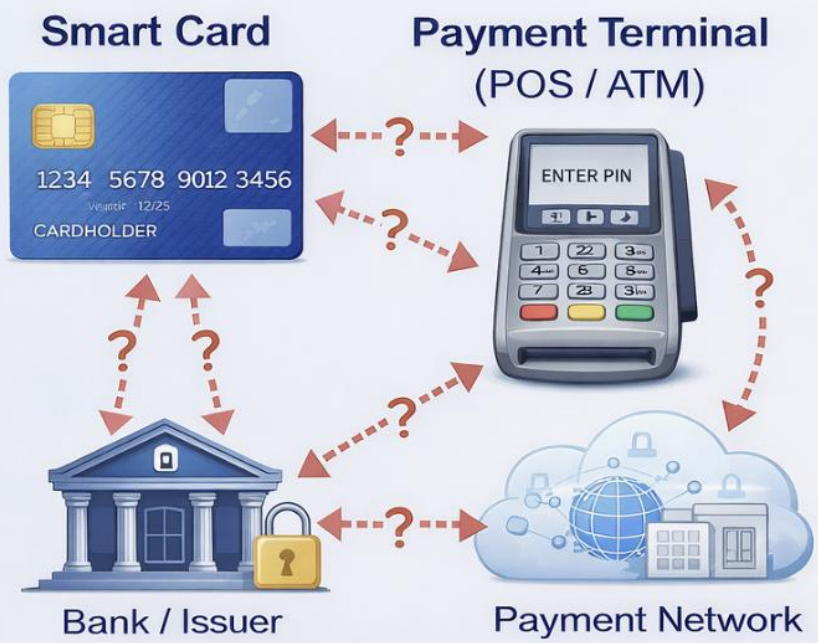
Trust Model (Without Attacks)

- Payment systems assume partial trust, not full trust
- Smart cards do not fully trust payment terminals
- Payment terminals do not fully trust smart cards
- Issuers do not fully trust cards or terminals
- Payment networks enforce rules and interoperability, not absolute security
- Trust is established using **cryptography**, **certification hierarchies**, and **risk limits**

Focus of this lecture: how trust is engineered and managed in real systems

Trust Model (Without Attacks)

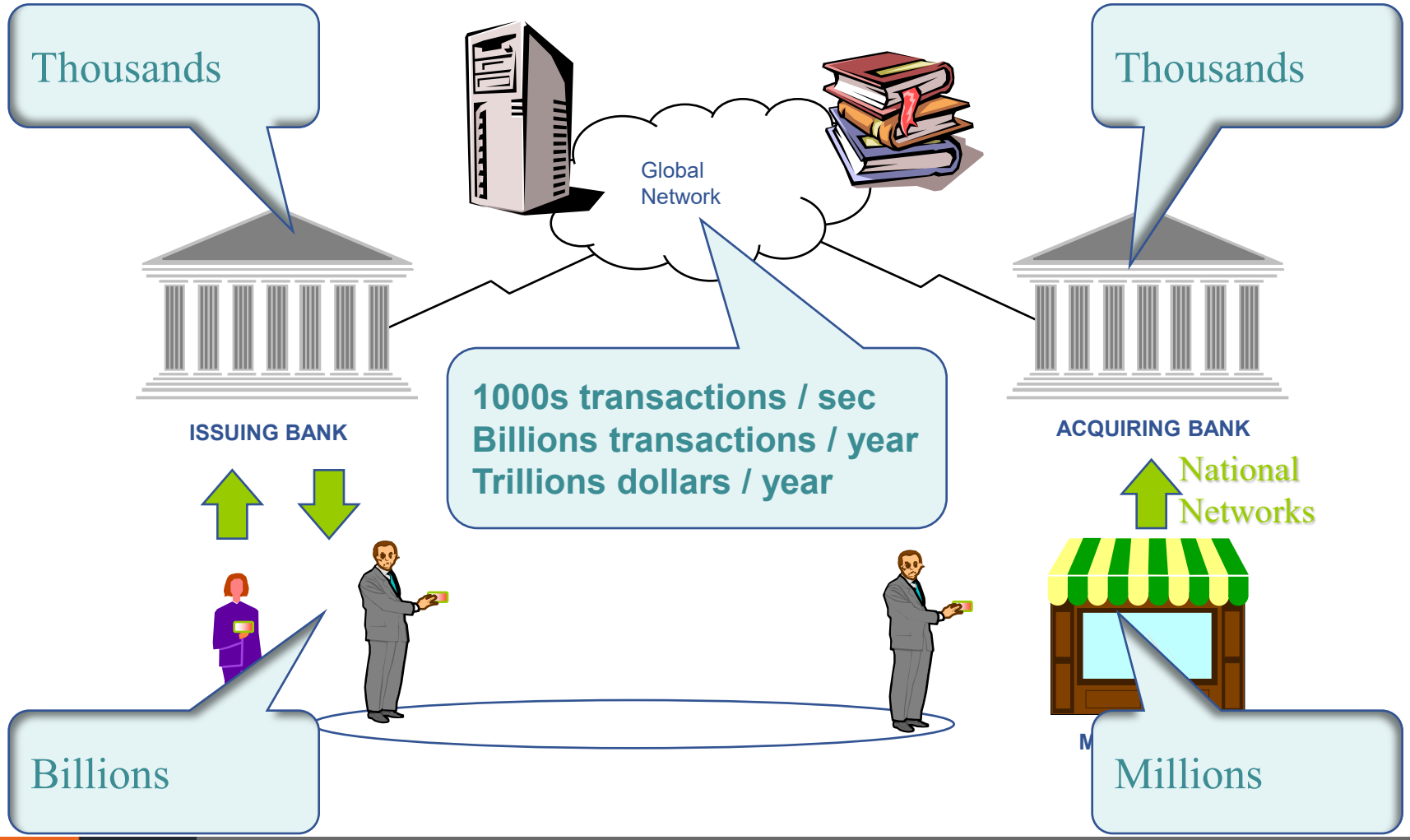
Payment Systems Assume Partial Trust, Not Full Trust



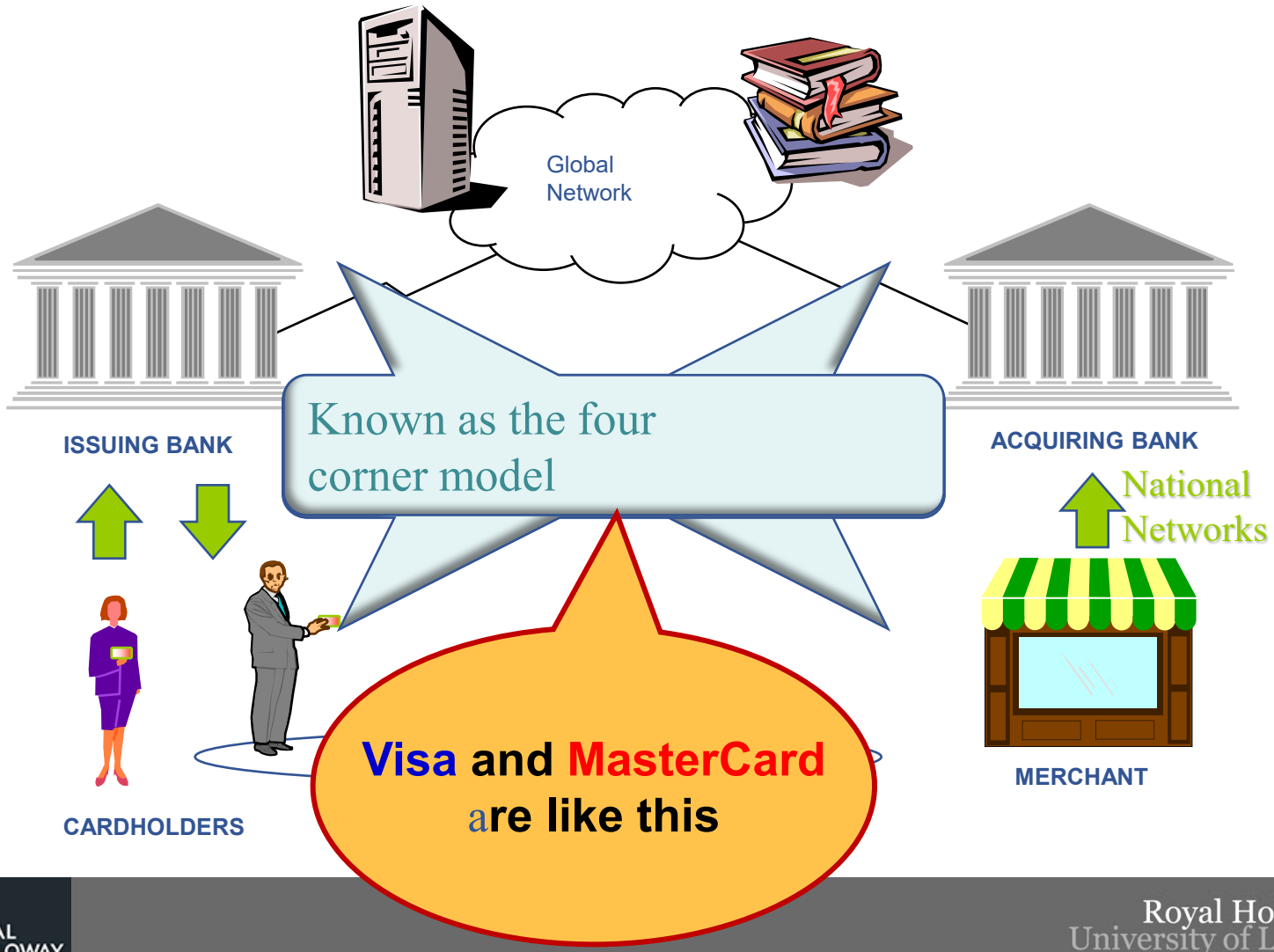
- Payment systems assume partial trust, not full trust
- Smart cards do not fully trust payment terminals
- Payment terminals do not fully trust smart cards
- Issuers do not fully trust cards or terminals
- Payment networks enforce rules and interoperability, not absolute security
- Trust is established using cryptography, certification hierarchies, and risk limits

Focus of this lecture: how trust is engineered and managed in real systems

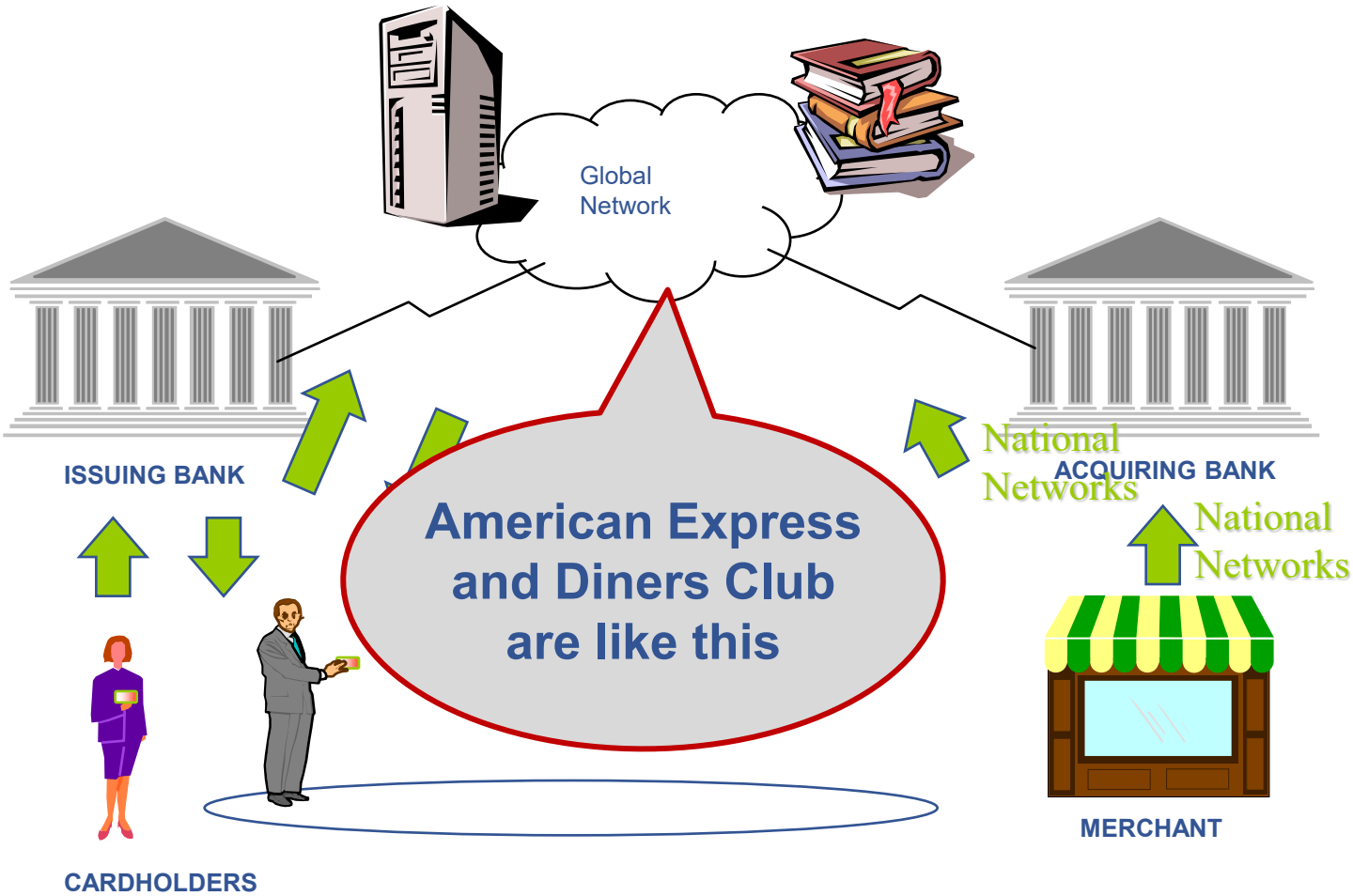
Payment Systems – the Big Picture



Payment Systems – the Big Picture



Payment Systems – the Big Picture



Reasons for Merging Acquirer and Merchant Services

- ✅ Full Control Over Transactions & Fees
- ✅ More Profitable Business Model
- ✅ Enhanced Merchant Relationships
- ✅ Exclusive Merchant Acceptance Strategy
- ✅ Competitive Edge Against Visa & Mastercard
- ✅ Better Fraud Detection & Risk Management
- ✅ International Expansion & Market Penetration

How Does This Compare to Visa & Mastercard?

Feature	Amex/Diners (Closed-Loop)	Visa/Mastercard (Open-Loop)
Acquiring	Direct (Amex/Diners owns it)	Third-party banks process transactions
Merchant Fees	Set by Amex/Diners	Set by acquirers (banks)
Revenue Model	Earn from both cardholders & merchants	Earn mainly from network fees
Merchant Support	Directly controlled	Dependent on acquiring banks
Fraud Control	Full transaction visibility	Shared between acquirers & issuers

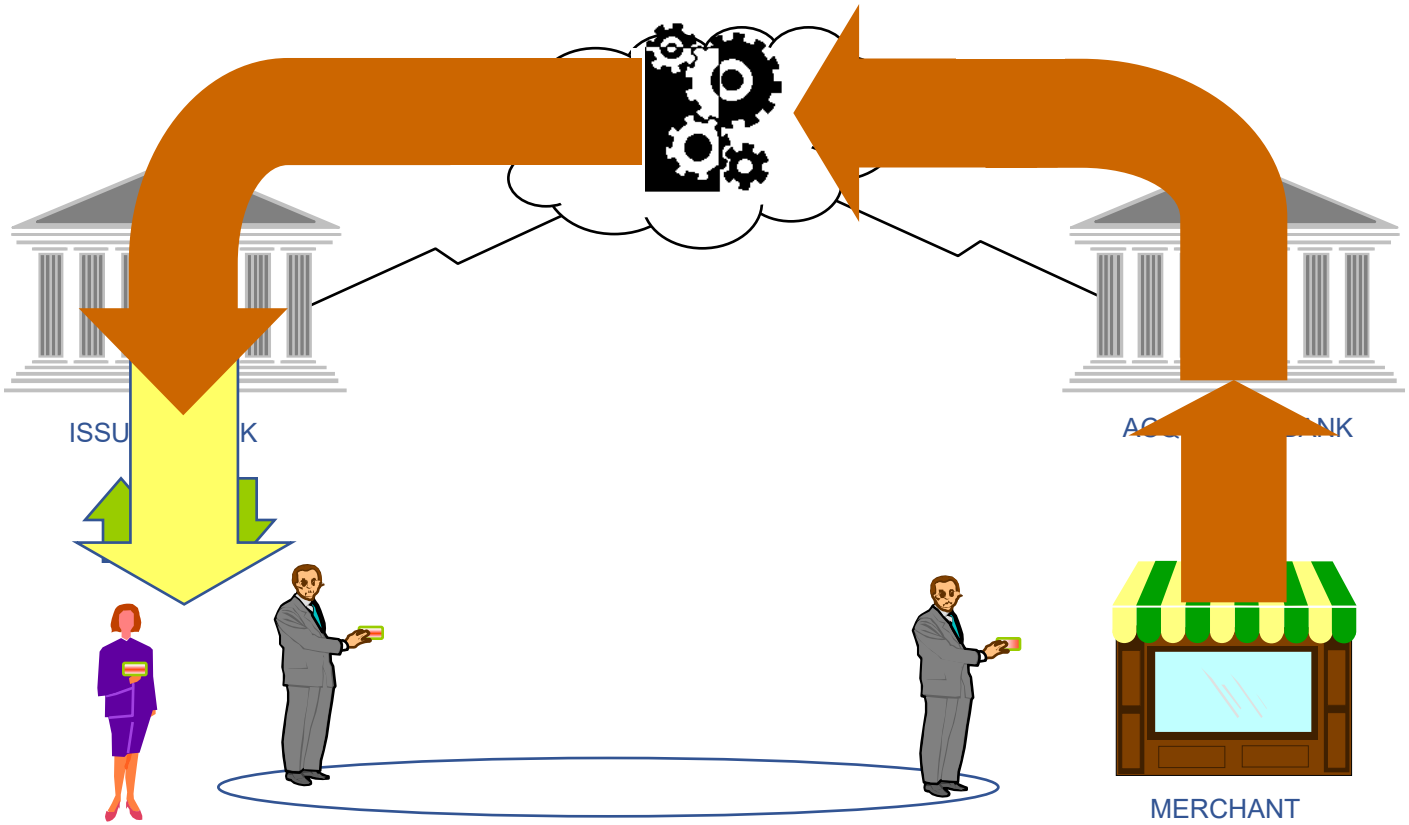
Credit, Debit, Charge, Pre-Paid?

- Transaction is the same
- A debit account deducts the transaction amount straight from the current account
- A credit account accumulates the transactions and issues a statement on a monthly basis
- Credit cards allow only a part of the sum to be paid – interest will be charged on the residue and added to next month's statement – "revolving credit"
- Charge cards are similar to credit, but the amount must be settled in full
- Pre-paid cards are like debit – against an separate account loaded with the initial funds. Some can be re-loaded

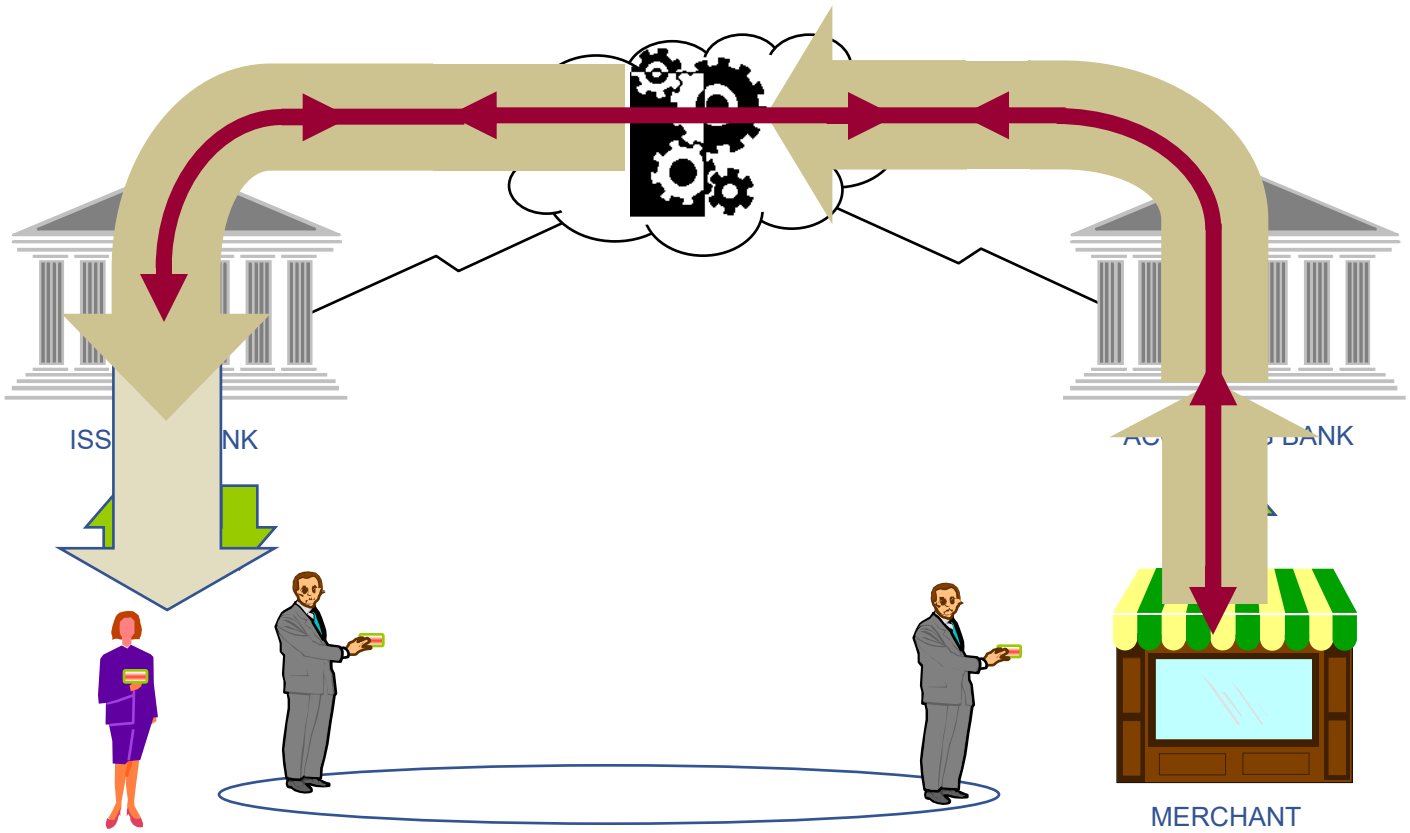
Comparison of Transaction Types

Transaction Type	Description
General Transaction	The transaction process remains the same.
Debit Account	Deducts the transaction amount straight from the current account.
Credit Account	Accumulates transactions and issues a monthly statement.
Credit Cards	Allow partial payment; interest is charged on unpaid amounts ('revolving credit').
Charge Cards	Similar to credit cards, but the full amount must be paid each month.
Prepaid Cards	Works like debit but against a preloaded account; some can be reloaded.

Clearing & Settlement



Authorisation



Risk Management as Trust Calibration

- Payment systems do not aim to eliminate fraud
- They aim to keep fraud within economically acceptable limits
- Security decisions are not absolute
  - Is this transaction safe **enough** given what we know right now?
- Trust levels are dynamically adjusted based on risk signals
- Examples of trust calibration:
  - Offline transaction limits
  - Counters and velocity checks
  - Selective online authorisation
  - Liability rules aligned with risk allocation

Risk Management

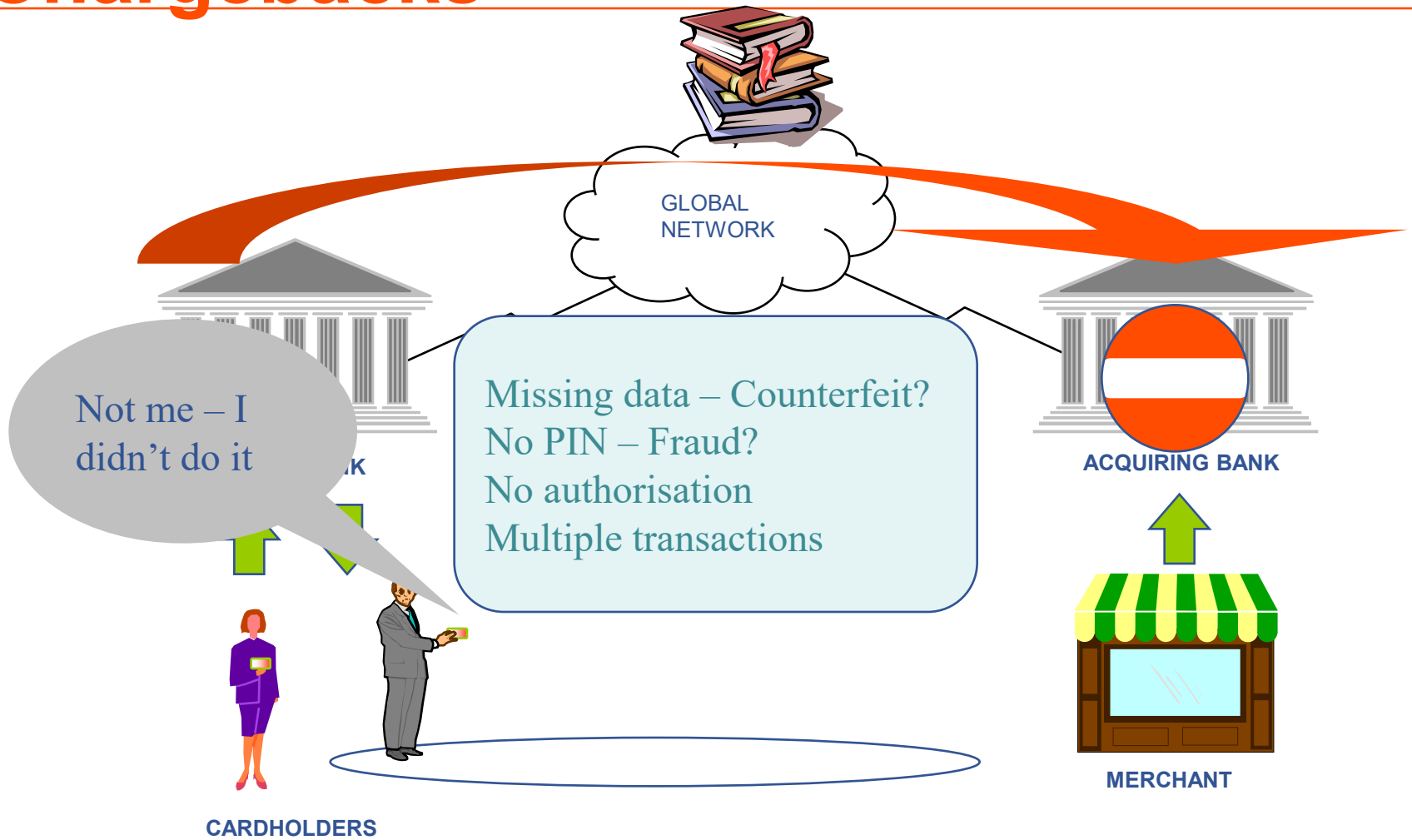
- Payment Systems run **Risk Management departments - not** “Risk Elimination” departments
- Objective **is risk mitigation** and fraud control to curb the level of fraud, but **balanced against the cost** of doing so
- Typical target is to bring **fraud down to below 0.01%** for both Issuers and Acquirers
- One of the underlying (business) requirements is to do this in a cost-effective way, using **devices**, **procedures** and **rules** which are fit for purpose

Fraud Rate Targets in Payment Systems*

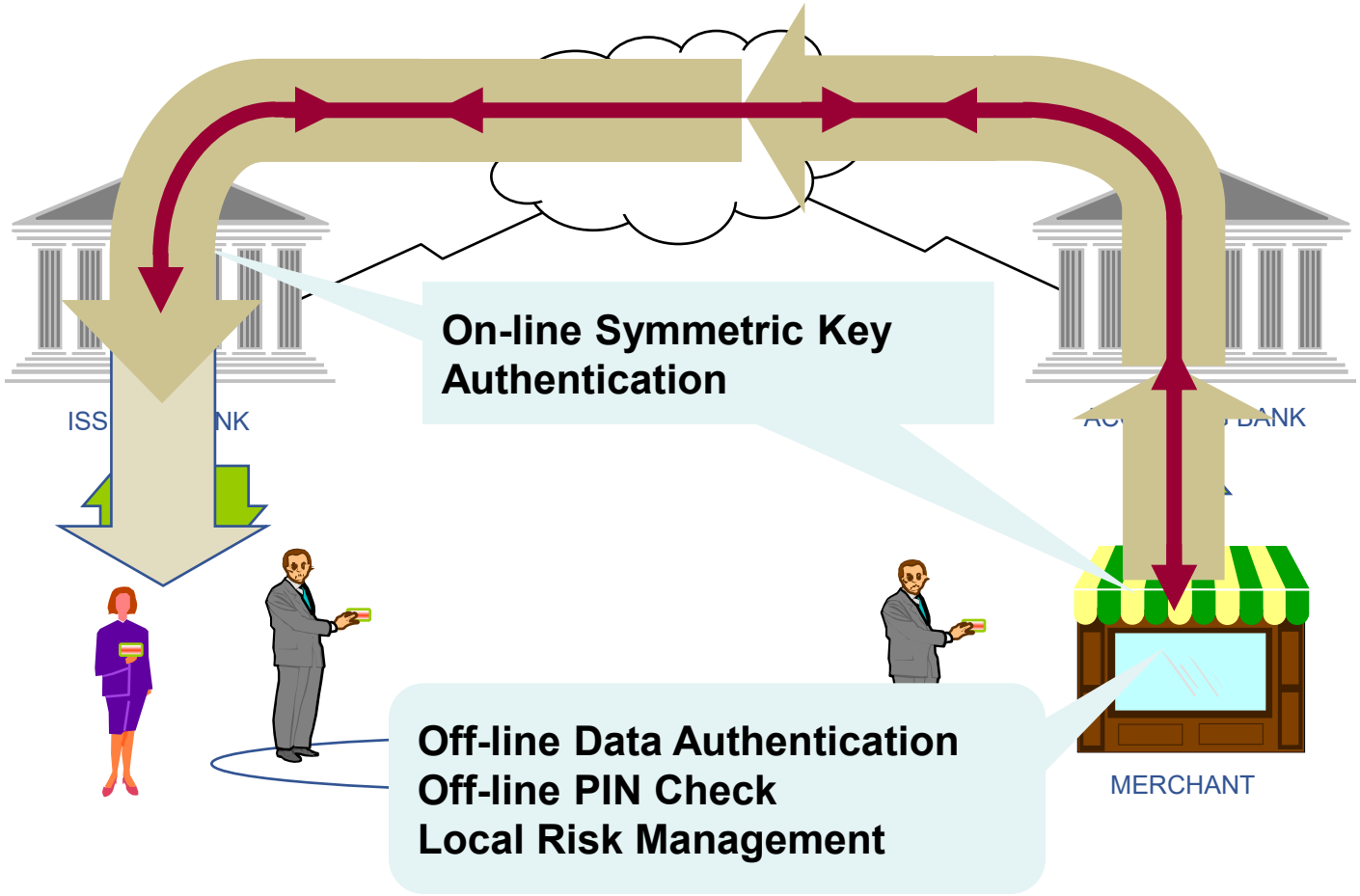
Payment System	Target Fraud Rate
Visa & Mastercard	Below 0.1% of total transaction value
American Express & Discover	0.05% - 0.08% of total transactions
Banking Systems (ACH, SEPA, SWIFT)	Below 0.02%
Real-Time Payments (RTP, UPI, FedNow)	Below 0.01% (stricter security)

* While specific target fraud rates for payment systems like Visa, Mastercard, American Express, and Discover are not publicly disclosed, industry reports provide insights into actual fraud rates

Chargebacks



Adding Chip


On-line Symmetric Key Authentication
ISS
NK
BANK
MERCHANT
Off-line Data Authentication
Off-line PIN Check
Local Risk Management

Standards & Specifications

Global payment systems are built on **international standards**, often supplemented by **industry or "company"** implementation specifications

ISO is the primary International standards organisation, but not the only one

- CEN – Comité Européen de Normalisation
- EPC / ISSG – EPC Information Security Support Group

Most countries maintain a National Standards Body, for example:

- BSI – United Kingdom
- DIN – Germany
- ANSI – United States
- AFNOR – France
- …

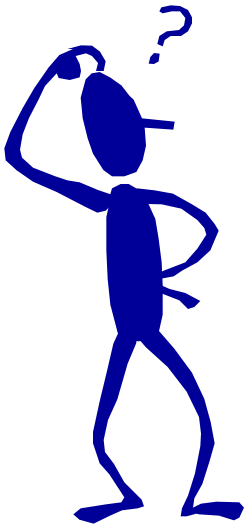
Standards & Specifications

- What does ISO stand for?
  - International Standards Organisation?
  - International Organisation for Standardisation?
- Actually it is not an acronym, but a prefix, stemming from the Greek *isos*, meaning equal
  - Root of *iso*, as in *iso*-bar, *iso*-therm

Standards & Specifications

- **EMV®** – was an acronym of Europay, MasterCard & Visa … now a registered trademark.
  - EMVCo is currently Amex, Discover, JCB, MasterCard, UnionPay and Visa
  - Working together they produced an implementation specification for use of chip cards in the payment transaction environment
  - Based on ISO standards – in particular 7816 for the chip electro-mechanical and command structure and 9796, 9797, 10116 & 10118 for the crypto
- **3D-Secure** - Visa sourced specification for e-commerce
- **CAP** - MasterCard sourced specification for Token Authentication

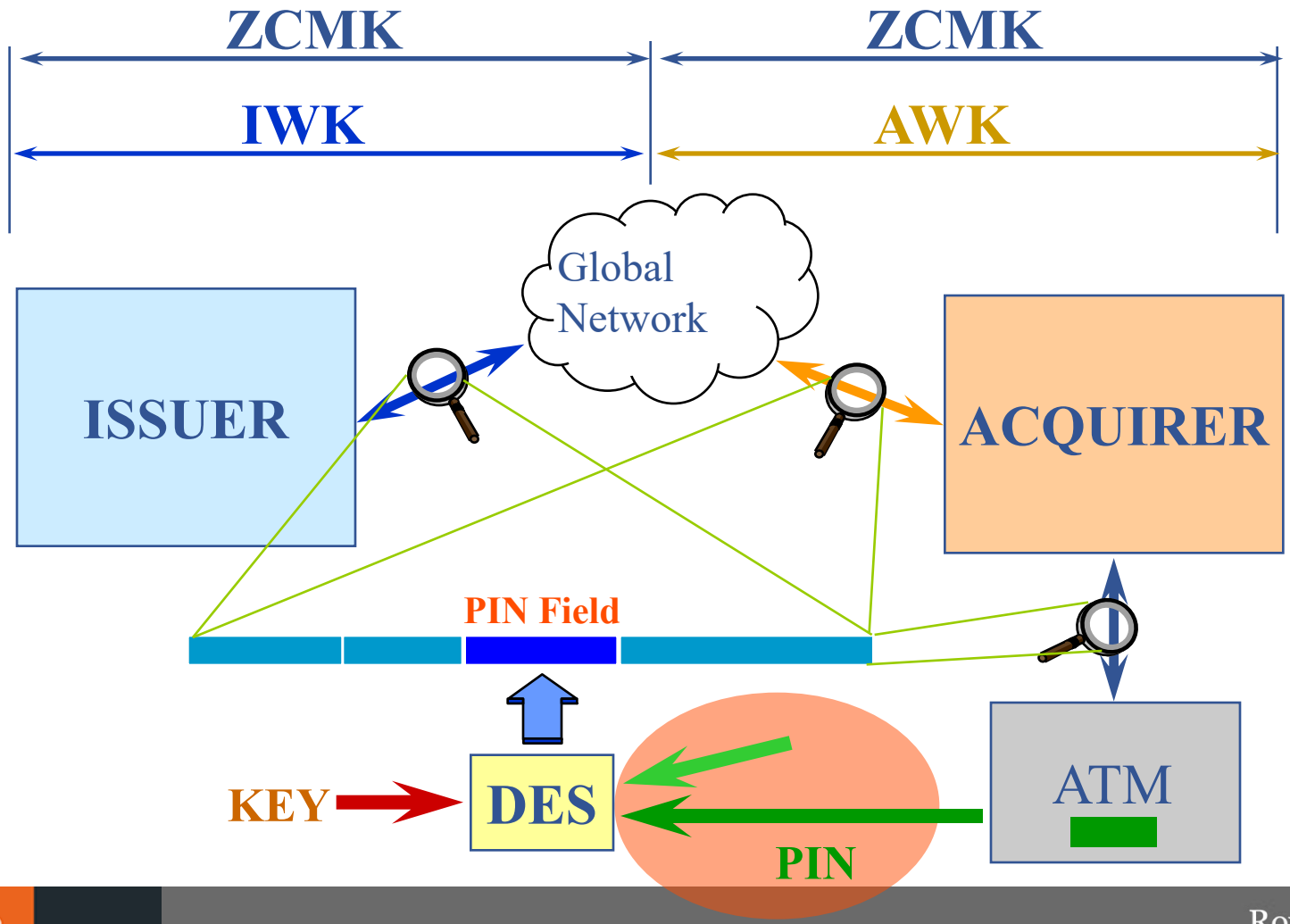
Any Questions?



Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication

PIN Protection



Zone Control Master Key (ZCMK)

- **What is a ZCMK?**
  - **ZCMK = Zone Control Master Key**
  - A **ZCMK is a master key used only to protect other keys when they move between trusted domains**.
  - It is a **key-encryption key**, not a data-encryption key
- Establishing a secure **key-exchange relationship** between institutions
- Each ZCMK exists **only between two specific trusted entities**.
- stored only inside the HSMs of those two parties

https://cpl.thalesgroup.com/encryption/hardware-security-modules

Role of Hardware Security Modules (HSMs)

HSMs are the trust anchors in payment infrastructures

- They provide a secure execution **environment** for cryptographic operations

Key protection and storage

- Master keys (**e.g.** ZCMKs) and working keys never leave the HSM in plaintext
- Keys are generated, stored, and used entirely within the HSM boundary

Secure cryptographic processing

- PIN encryption, PIN translation, and verification occur inside HSMs
- Keys are translated between domains without exposing PINs or keys

Trust separation and enforcement

- Each domain (ATM, Acquirer, Network, Issuer) relies on its own HSMs
- Cross-domain trust is explicitly mediated by HSM-protected keys

Damage containment

- Compromise outside the HSM does not expose keys or PINs
- No single system or operator can extract sensitive material

PIN Block Format

PINs which happen to be the same, should not encrypt to the same value.

ISO 9564-1 Format 0

String 1 – 16 Hex digits

0	4	1	2	3	4	F	F	F	F	F	F	F	F	F	F
	Len	— PIN —				—				Pad				—	

String 2 – 16 Hex digits

0	0	0	0	0	0	1	2	3	4	5	6	7	8	9	0
	Zero fill			—			right 12 digits PAN							—	

XOR

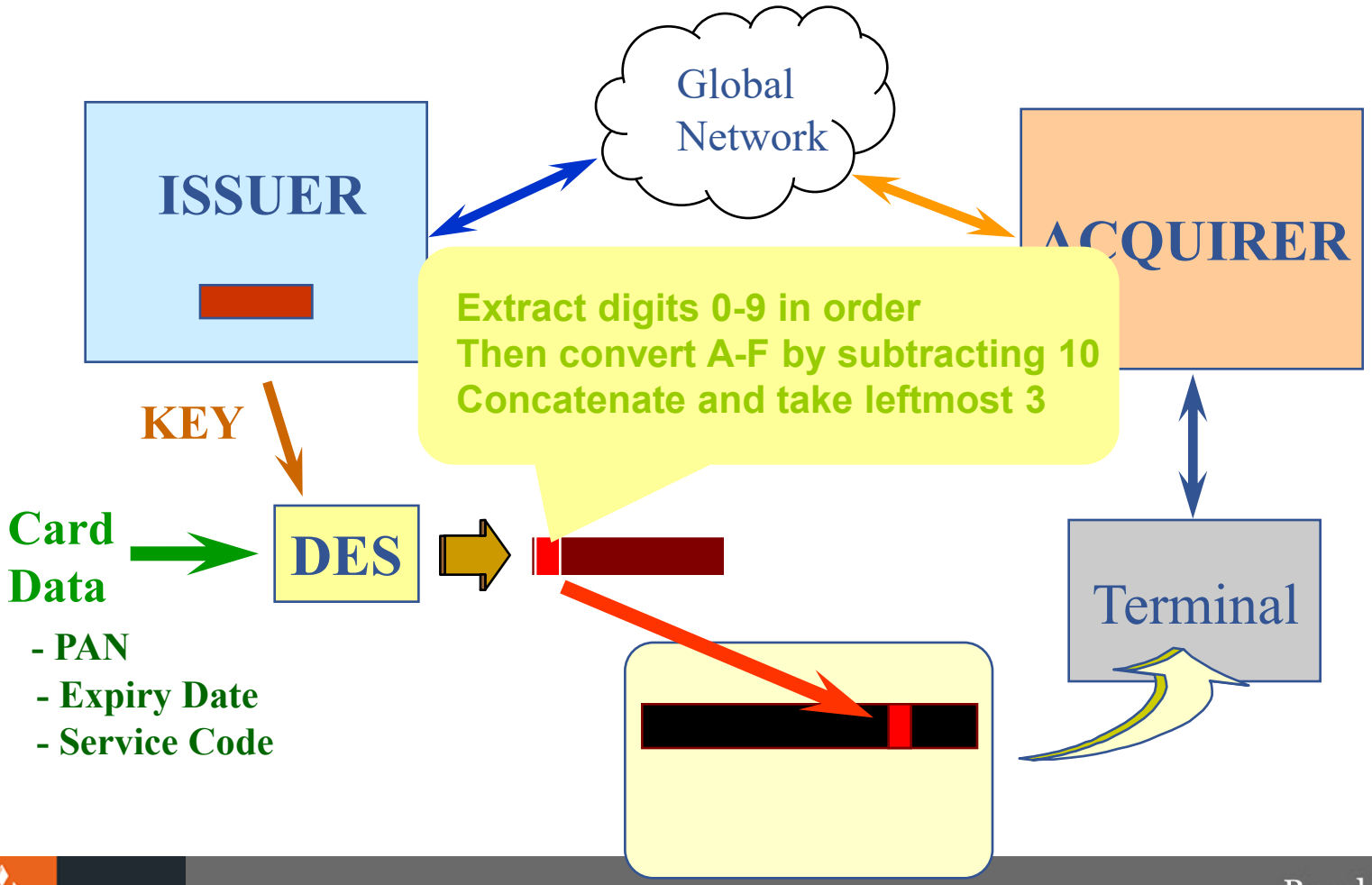
0	4	1	2	3	4	E	D	C	B	A	9	8	7	6	F

ISO 9564-1 Format 3 is same except pad values vary from A to F

When PIN Block Formatting Occurs

- PIN block construction occurs immediately after PIN entry
- The operation takes place inside the secure PIN-entry device (ATM or POS)
- PIN block formatting happens before encryption
  - The PIN is combined with card-specific data (PAN digits)
  - XOR is used to create a fixed-length PIN block
- The cleartext PIN block exists only momentarily within secure hardware
- The PIN block is then encrypted and transmitted
  - The PIN is never sent or processed in plaintext outside secure hardware

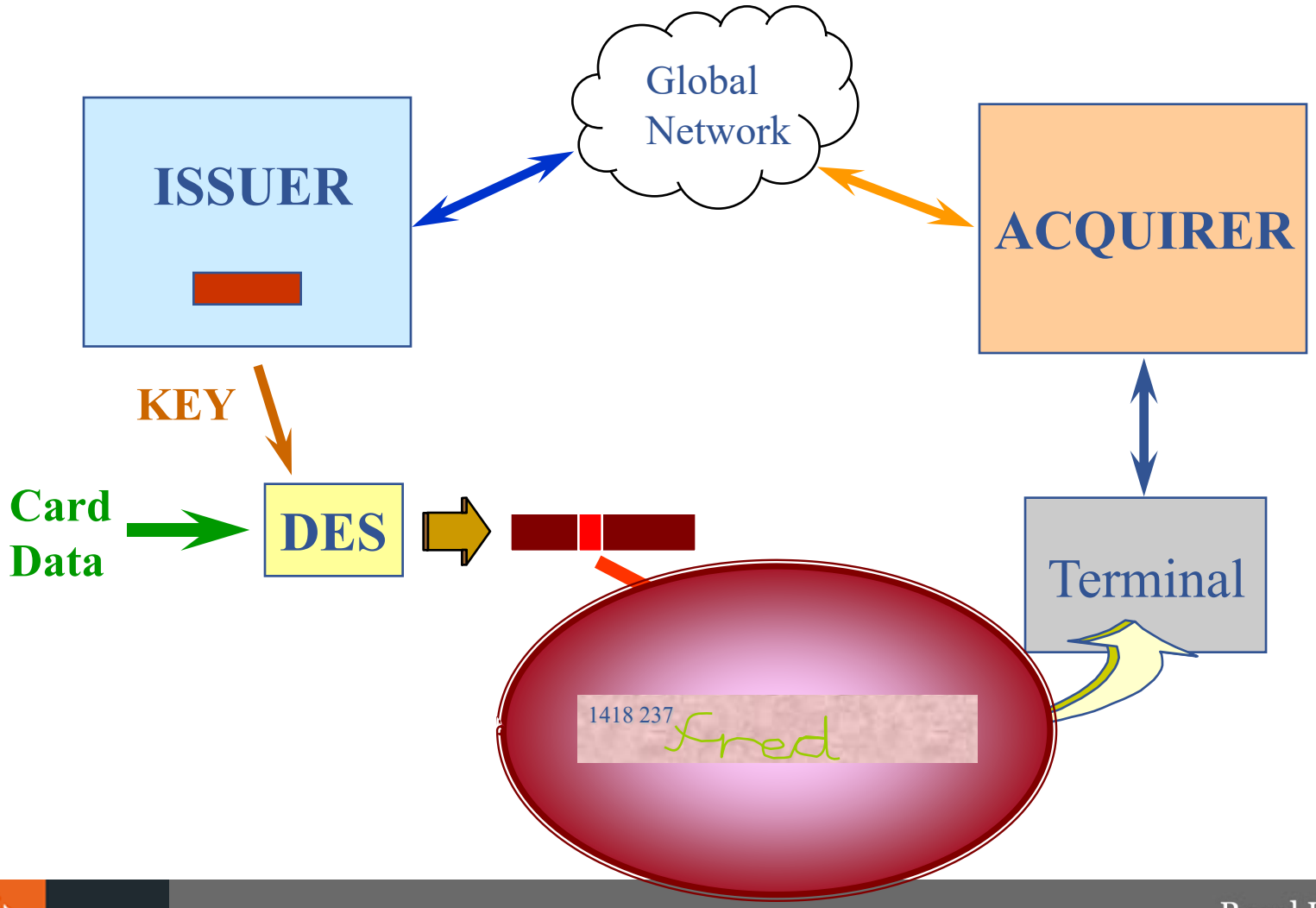
CVV (Card Verification Value)



CVV (Card Verification Value): What It Does

- Purpose: allows the issuer to verify that card data is genuine
- How it works:
  - Derived from card data (PAN, expiry date, service code)
  - Calculated using a secret issuer key
  - Issuer recomputes and checks the value during a transaction
- What a match means:
  - Card data has not been altered or fabricated
- What CVV does not do:
  - Does not encrypt data or authenticate the cardholder

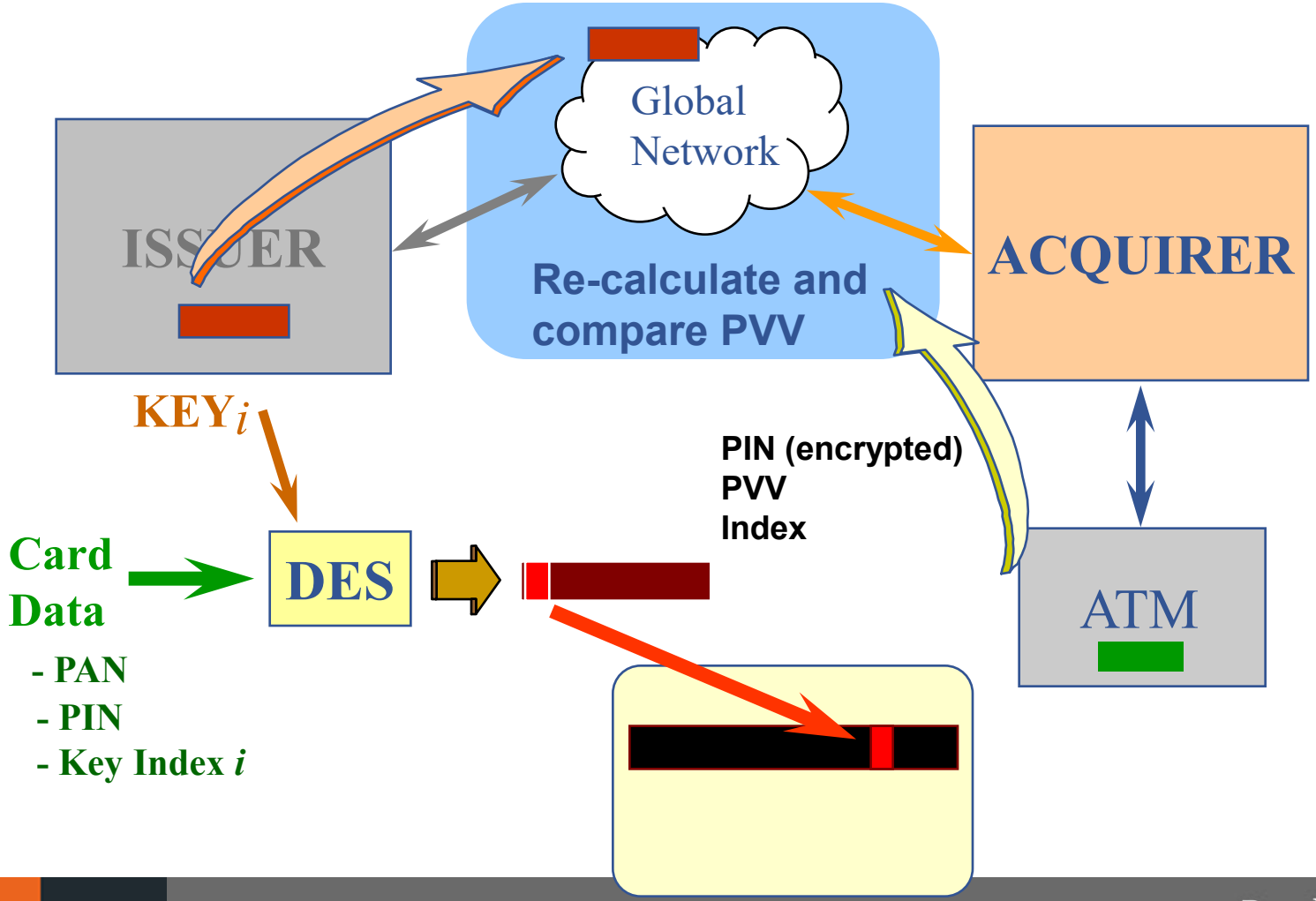
CVV2


Global
Network
ISSUER
ACQUIRER
KEY
Card
Data
DES
Terminal
1418 237
fred

CVV2: Card-Not-Present Verification

- Purpose: provides a weak proof that the cardholder has physical possession of the card
- Where it is used:
  - Online, phone, and mail-order transactions
- How it works:
  - Derived by the issuer from card data using a secret key
  - Printed on the card, but not stored in the mag-stripe or chip
  - Issuer recomputes and compares the value during authorisation
- Limitations:
  - Does not authenticate the cardholder or prevent all fraud

PIN Verification Value (PVV)



PVV-Based PIN Verification: Who Does What

- PVV enables PIN verification without revealing or storing the PIN
- Issuer role:
  - Generates and stores the PVV and key index during card personalisation
  - Shares the corresponding verification key with the payment network
- Network role:
  - Performs PIN verification in network HSMs on behalf of the issuer
  - Never learns or stores the PIN
- Key benefit:
  - Scalable, secure PIN verification with delegated and limited trust

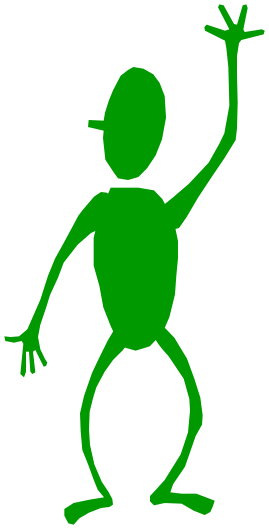
CVV & PVV Size

- 3 digits (CVV & CVV2) is 1:1,000 guess
- 4 digits (PVV) is 1:10,000 guess
  = PIN guess for 4 digit PIN
- Online authorisation system limits attacker scope
- Issuers can detect attacks after a small number of attempts and can respond accordingly

PIN Verification Models: Who Verifies the PIN?

- Terminal-Based PIN Verification (Mag-stripe / Early ATM)
  - PIN captured and encrypted by the ATM
  - PIN verification performed centrally (issuer or network)
  - No smart card involvement; card is passive
- Online PIN (Issuer Verification)
  - Encrypted PIN block sent to issuer
  - Issuer HSM performs PIN verification
  - Strong control, but requires issuer availability
- PVV-Based PIN Verification (Network)
  - PIN captured at ATM and sent encrypted
  - Payment network verifies PIN using PVV on behalf of issuer
  - Scalable, delegated trust without storing PINs

Any Questions?



Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication

EMV Chip

- Offline Data Authentication – SDA/DDA/CDA
- Card Authentication
- Issuer Authentication
- Transaction Certificate
- Management Functions (Script processing)

Why Offline Cryptography Exists

- Payment systems must operate reliably without continuous network connectivity
- Offline cryptography enables:
- Low-latency transaction processing
- High availability at point of sale
- Continued operation during network outages
- Global scalability across diverse infrastructures
- Offline processing requires local trust decisions and bounded risk exposure
- Risk is managed using limits, counters, and cryptographic verification

Offline Data Authentication

- Operates locally between card and terminal.
- **SDA**
- demonstrates to the terminal that the card data has not changed since it was personalised by the issuer.
- **DDA**
- demonstrates the above, plus that the card contains a unique private key linked through the certificate chain.
- **CDA**
- demonstrates both the above, plus that the on-line cryptogram has not been substituted by a “wedge” attack.
- Note: Since most cards now support public key crypto, SDA is little used today.

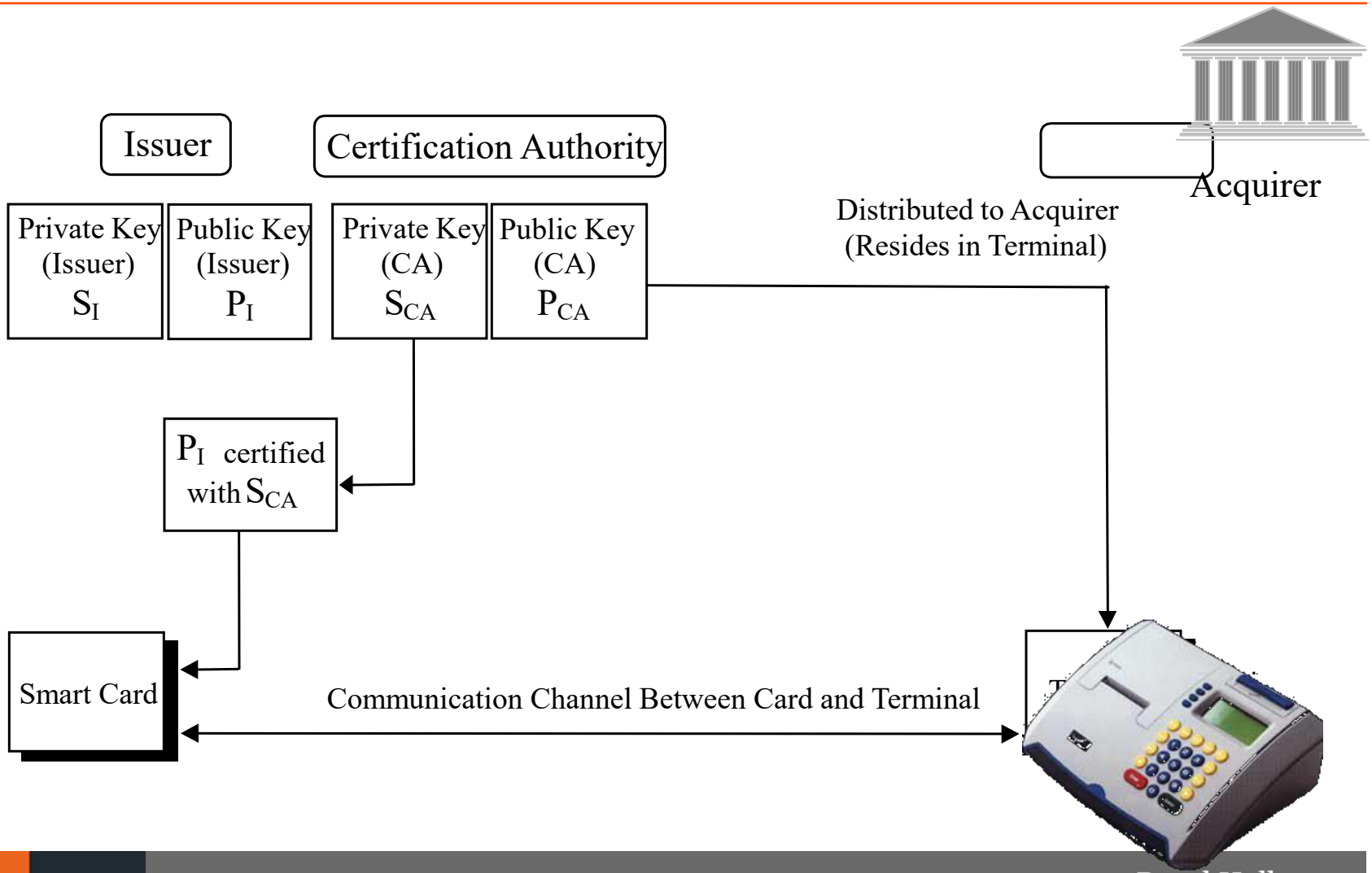
Static Data Authentication

- SDA provides “static protection” of ICC data integrity by the Issuer.
- Enables detection of unauthorised alteration of data after personalisation.
- Little protection against replaying attacks.

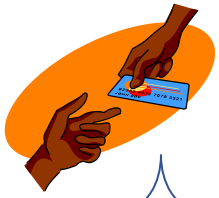
The Payment Terminal as an Embedded Policy-Enforcing System

- Payment terminals are embedded systems, not passive card readers
- They operate under constrained trust assumptions
- The terminal is responsible for:
  - Verifying certificate chains and public keys
  - Enforcing Cardholder Verification Method (CVM) rules
  - Deciding offline versus online transaction processing
  - Applying scheme, regulatory, and merchant policy
- Terminals enforce policy but do not hold long-term issuer secrets

Static Data Authentication (SDA)



EMV – Off-line Static Data Authentication (SDA)



Certification Authority

Issuer Private Key S_I	Issuer Public Key P_I	CA Private Key S_{CA}	CA Public Key P_{CA}

P_I Certified with S_{CA}

Card to Terminal

P_I certified by CA

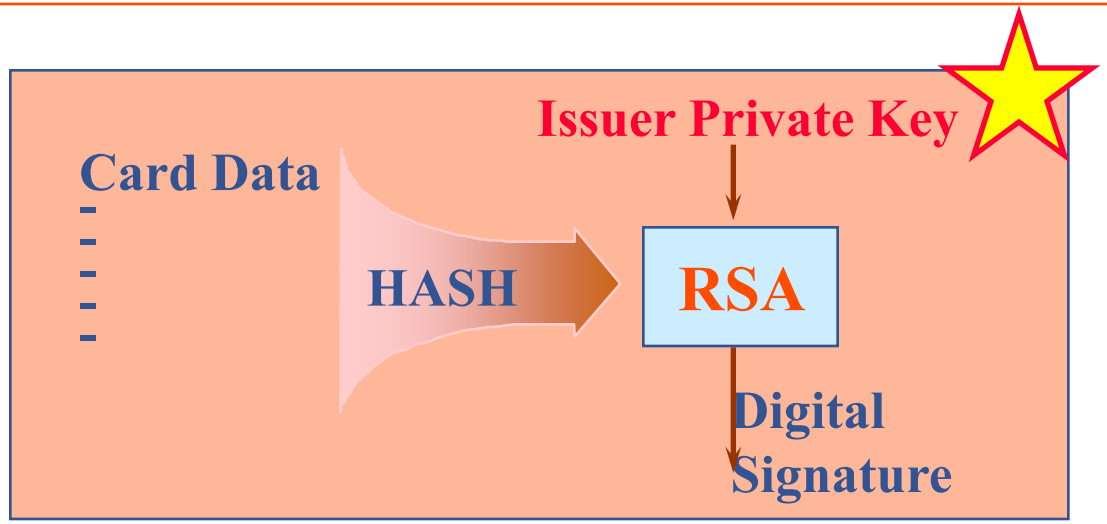
+Data with digital signature

Terminal

Uses P_{CA} to verify Issuers P_I

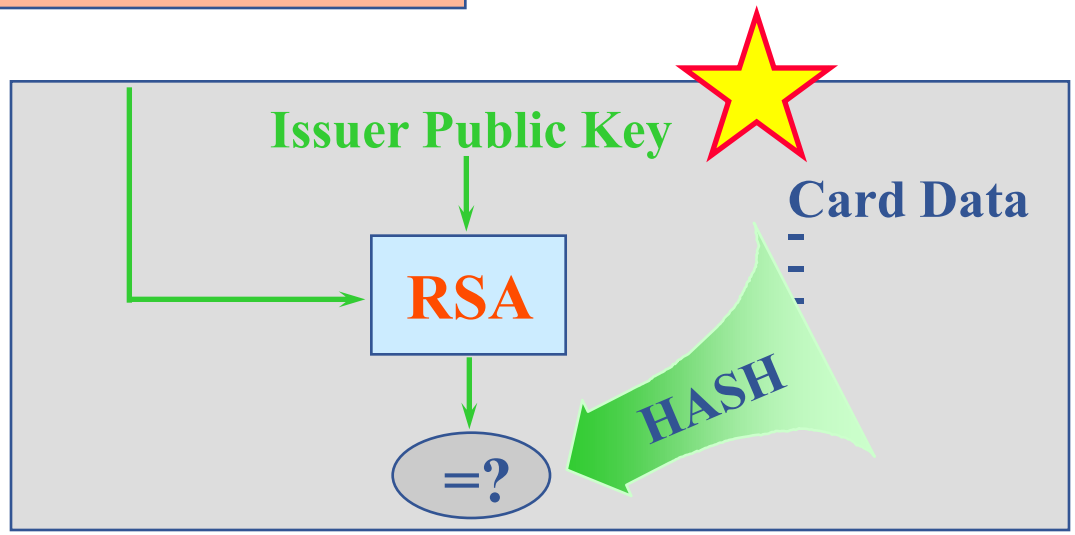
Uses P_I to verify data signature

Static Data Authentication (SDA)



Done once during personalisation - stored in card

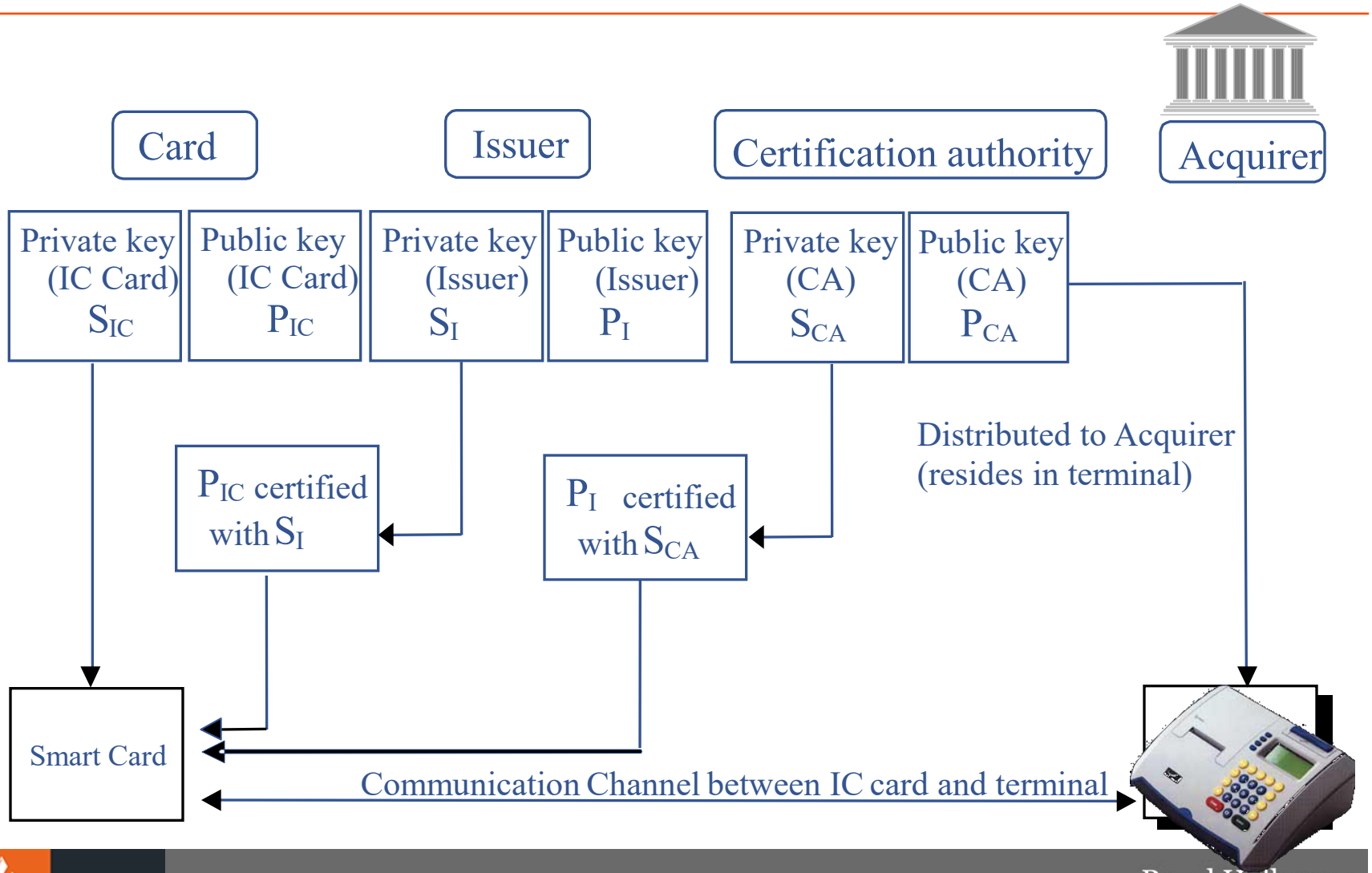
Done by a terminal for each transaction



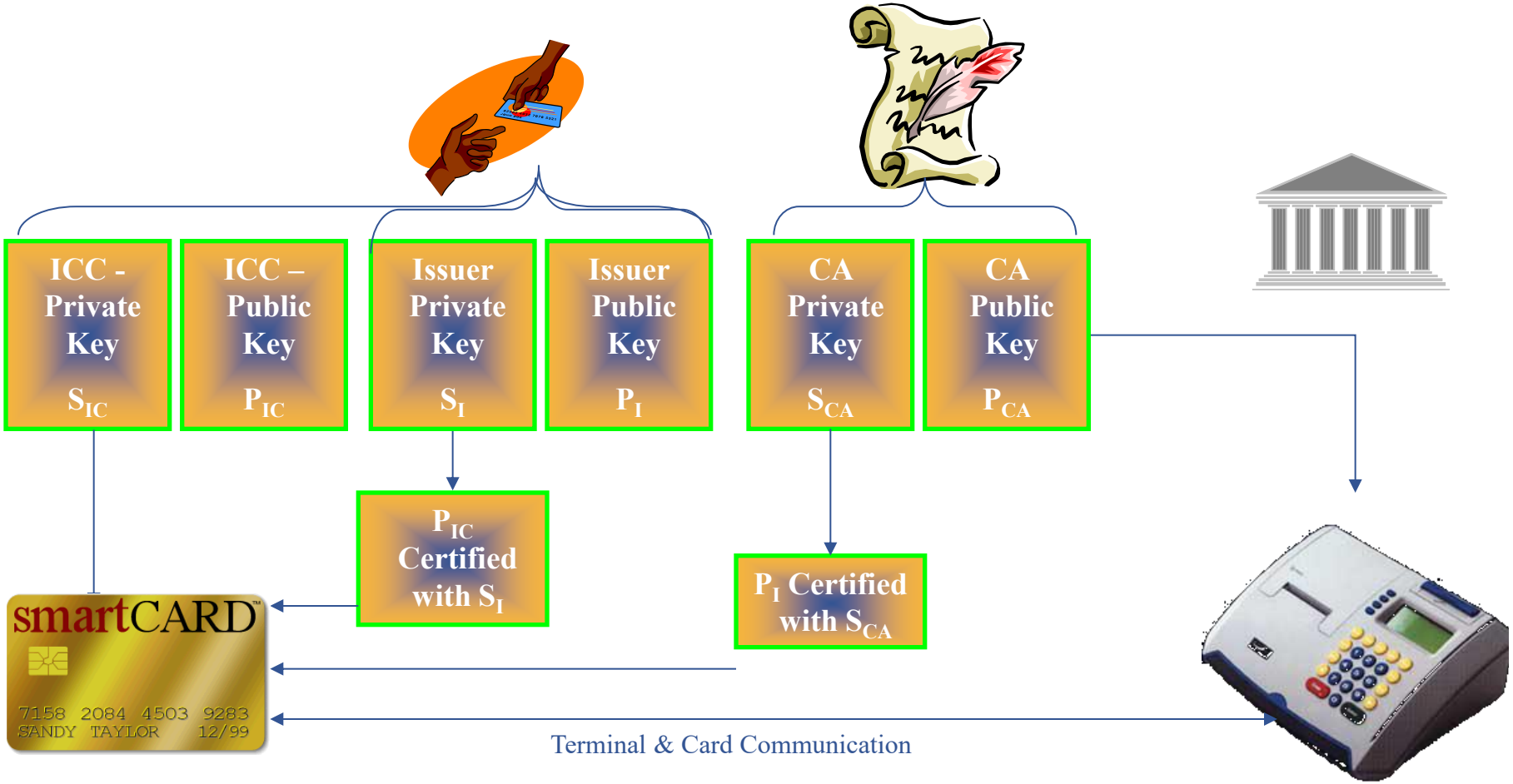
Dynamic Data Authentication

- DDA provides protection on the integrity of ICC / Terminal data by the ICC.
  - Prevents counterfeiting of the ICC.
  - Terminal data (an unpredictable number) to be authenticated
- Involves one more step than SDA

Dynamic Data Authentication



EMV – Off-line Dynamic Data Authentication (DDA)



Card to Terminal

P_{IC} certified by Issuer + P_I certified by CA

Data with digital signature

Terminal

Uses P_{CA} to verify Issuers P_I

Uses P_I to verify Card's P_{IC}

Uses P_{IC} to verify data signature

Combined Data Authentication

- Combined Data Authentication (CDA)
  - is essentially an enhanced version of DDA
  - the process is very similar.
- The main difference is that the Application Cryptogram (AC) computed by the ICC as a function of the transaction details, is included in the data signed by the ICC as part of Data Authentication.
- This prevents certain ‘wedge’ attacks.

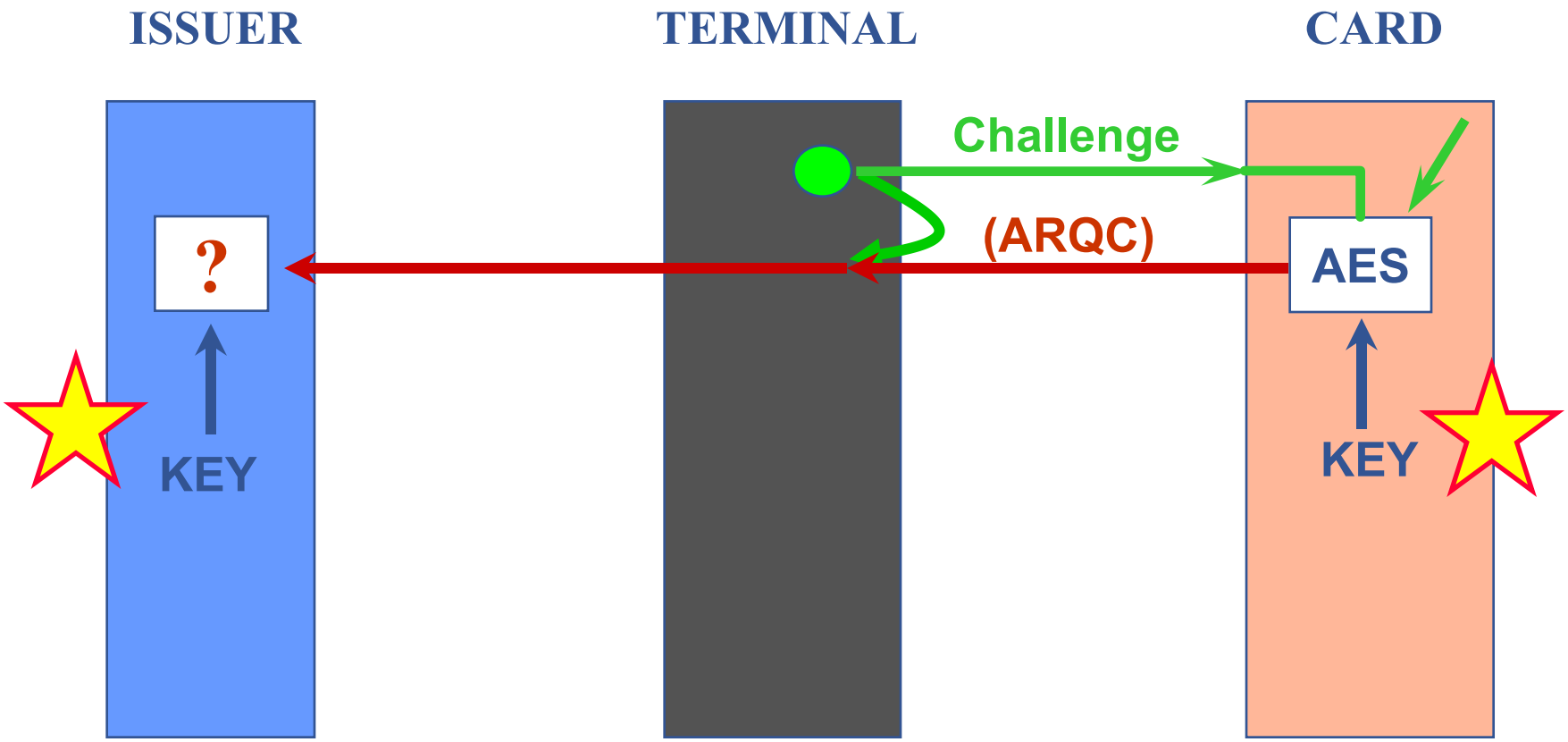
Offline PIN Check

- Plaintext
  - Straightforward - PIN block sent “in clear” in VERIFY command
- Encrypted
  - PIN block encrypted using card Public key and sent in VERIFY command
  - Card decrypts with private key and verifies
  - Key can be for PIN encryption only with additional certificate chain

Card Authentication

- Operates online
- Demonstrates to Issuer that card contains genuine key loaded during personalisation

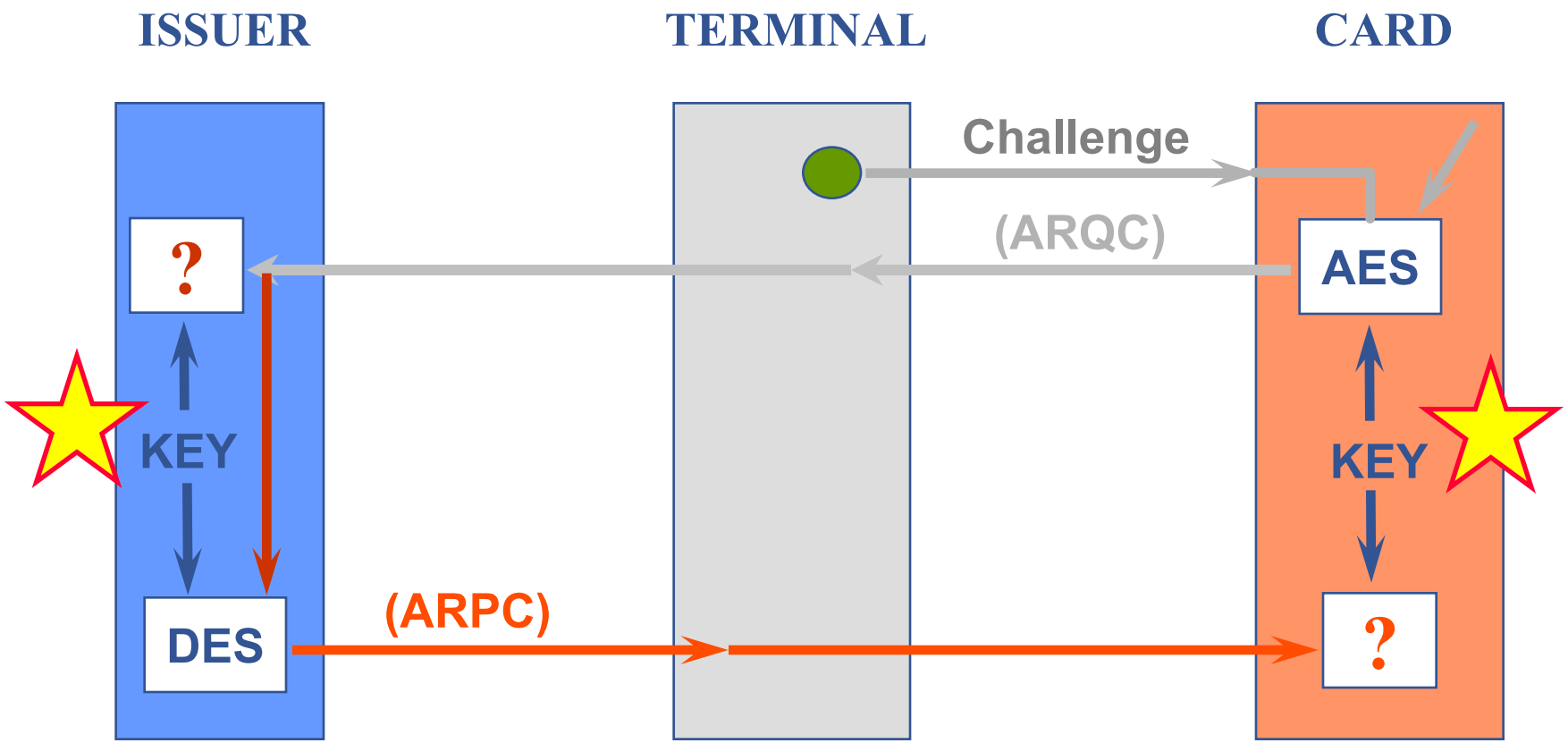
Card Authentication



Issuer Authentication

- Operates online
- Demonstrates to the card that the connection is with the genuine Issuer who personalised the card

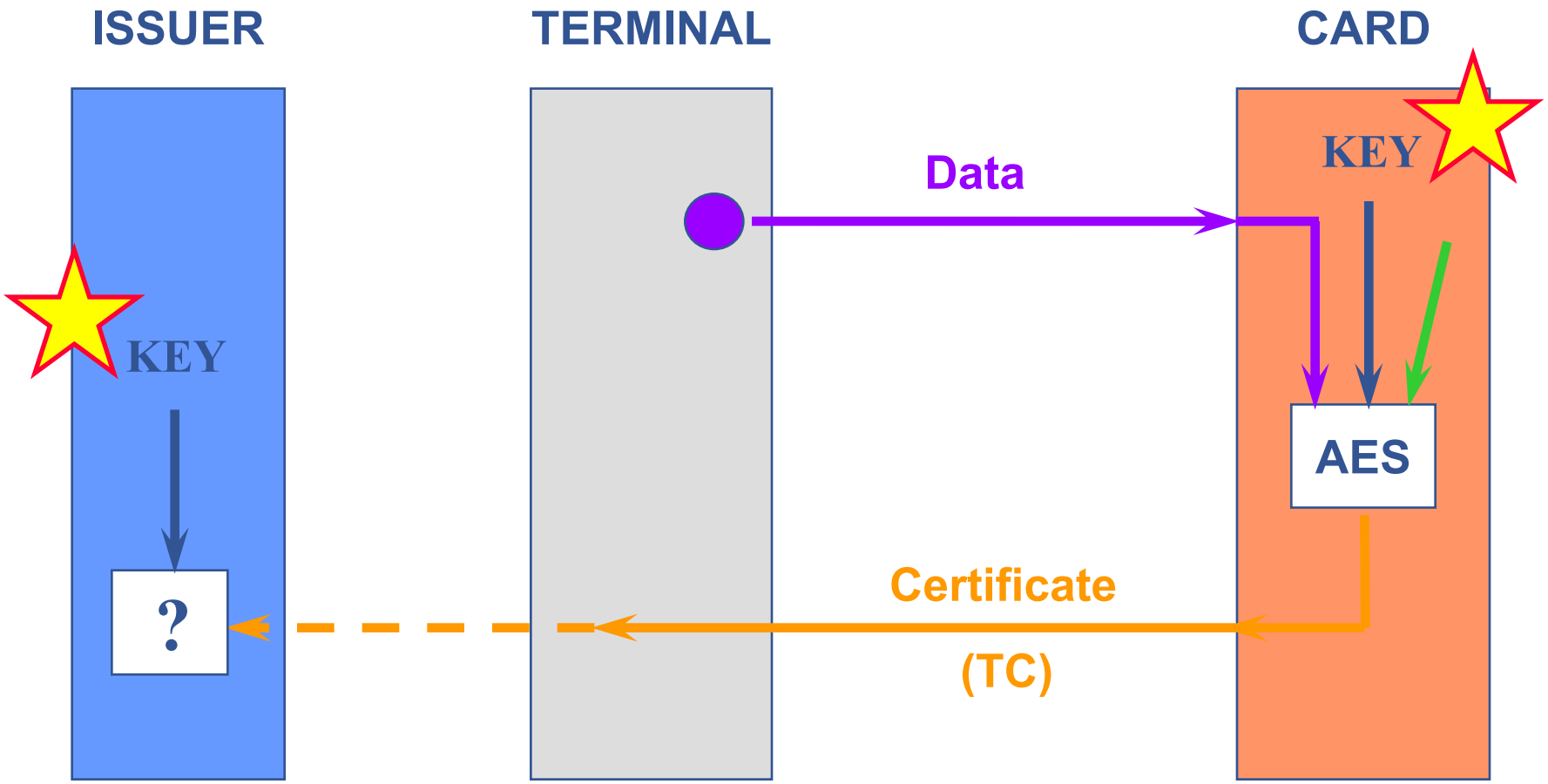
Issuer Authentication



Transaction Certificate

- Performed on complete transaction
- Sent with Data Capture record

Transaction Certificate



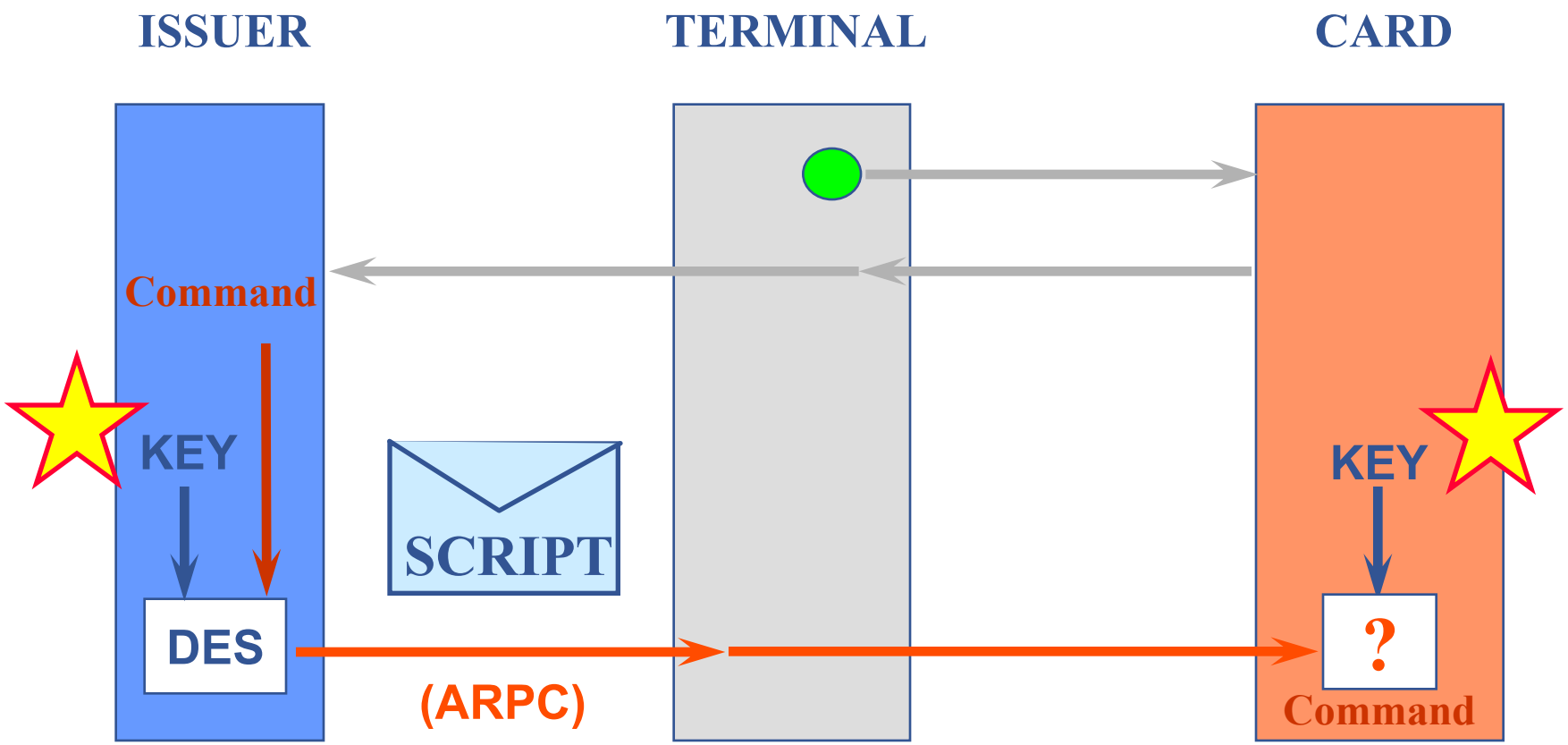
Cryptography as Engineering, Not Perfection

- Cryptographic design in payment systems is driven by engineering constraints
- Design factors include:
  - Global interoperability across billions of devices
  - Long deployment lifecycles measured in decades
  - Backward compatibility with legacy infrastructure
  - Performance and latency constraints at point of sale
- Resulting choices prioritise scalable, sustainable security rather than theoretical optimality

Script Processing

- Performed after transaction completed
- Possible script functions
  - PIN change
  - PIN unblocking
  - Update of card data elements
  - Application blocking/unblocking
  - Card blocking
- Transmitted using Secure Messaging

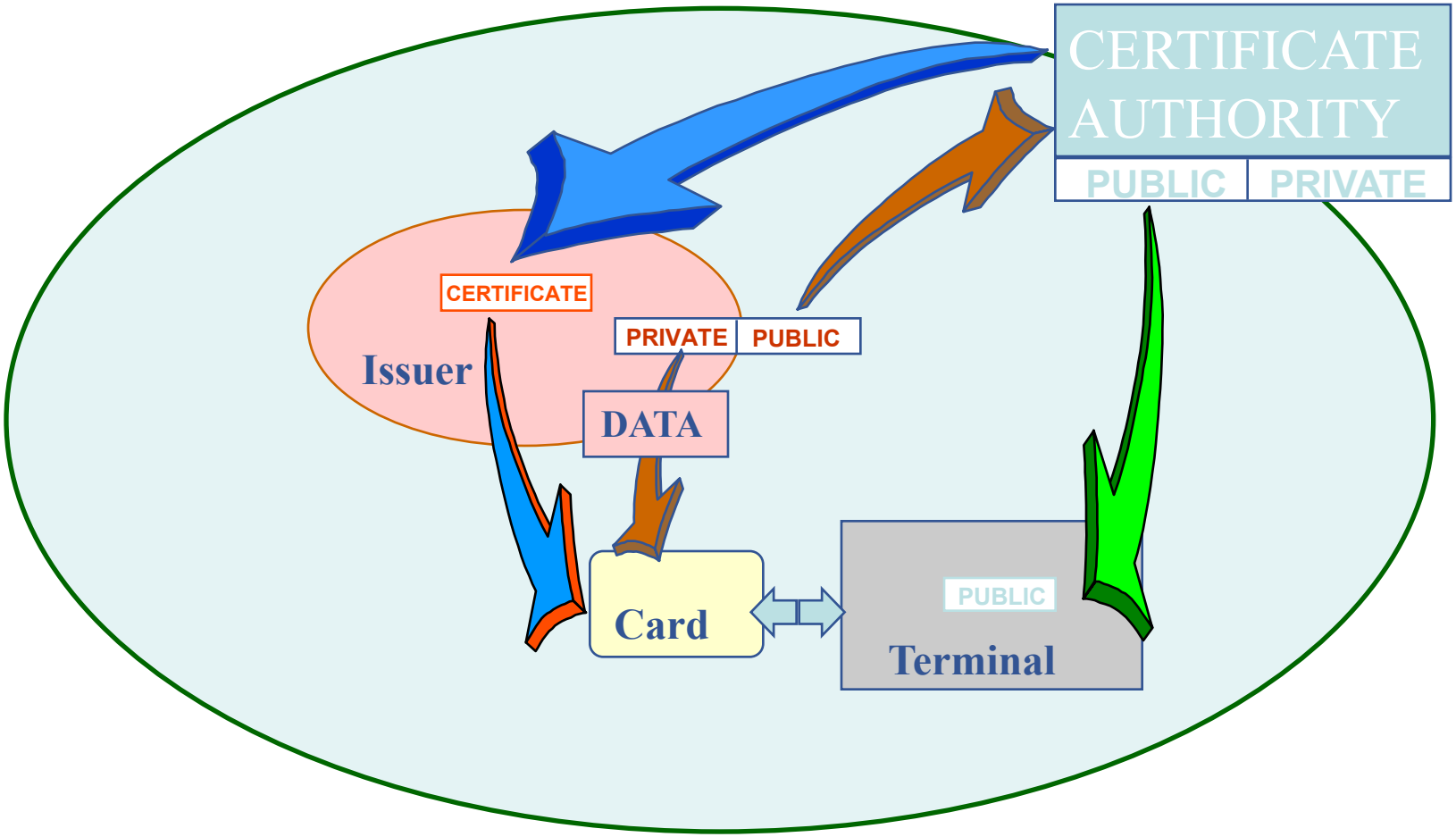
Script Processing



Key Management

- Two classes of Keys
  - RSA keys (public)
  - DES keys (secret)

RSA Keys


CERTIFICATE AUTHORITY
PUBLIC
PRIVATE
CERTIFICATE
Issuer
PRIVATE
PUBLIC
DATA
Card
PUBLIC
Terminal

RSA Keys

- Payment System Public Keys
  - Several lengths (768, 896, 1024, 1152, 1408 &1984)
  - Distributed globally
  - Longer key lengths required over time
- Issuer Keys
  - Signed by Payment System Certification Authority
  - Card Data and Certificates signed by Issuer Private Key
- Card Keys
  - Key pair per card (DDA/CDA)

Current Length of Payment System Public Keys

Payment Network	Public Key Length	Details
Visa	1536 bits	Used in transit fare gate terminals.
Mastercard	1984 bits	Key Index 06, valid until at least 2028.
American Express	1152 bits	Implemented in Amex payment systems.
NIST Recommendation	2048 bits	Suggested minimum for RSA security.

For context, the **National Institute of Standards and Technology (NIST)** recommends a minimum of 2048-bit keys for RSA to ensure adequate security.

Key Personalisation

- Each card needs its keys personalised securely during production – maybe 1,000s of cards per hour.
- DES keys are quick and derivation process is suited to localised HSMs in production bureau.
- RSA keys are not “derivable”. Each needs two randomly generated prime numbers that have to be checked for primality.
- Can be pre-produced by issuer (secure transfer required) or created locally (needs processing resource). Some cards can create their own key pair - code only used once.

What Now?

Enhancement:

- Update offline cryptography to ECC with key sizes that are likely good for all time
- Online cryptograms have little need to change, but are expected to migrate to AES.

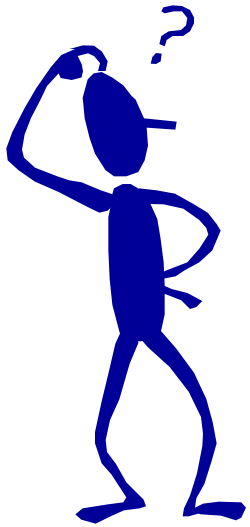
When:

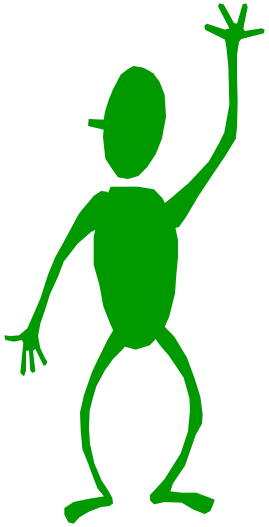
- Start in next 1-2 years allowing long migration before RSA keys are likely to run out of steam ~ 2030.

Commentary on Payment System Key Enhancements

- Enhancement: Transition from RSA to ECC for Offline Cryptography
- Why ECC?
  - **Elliptic Curve Cryptography (ECC)** provides the same level of security as **RSA but with much smaller key sizes**.
  - For example, **256-bit ECC** offers security equivalent to **3072-bit RSA**, making it **faster and more efficient** for payment processing.
  - RSA and ECC are *both* vulnerable to quantum attacks; ECC is adopted today for efficiency, not quantum resistance.
- RSA is expected to become weaker as computational power increases.
- Quantum computing advancements could break RSA encryption by 2030, making current RSA-based payment security obsolete.

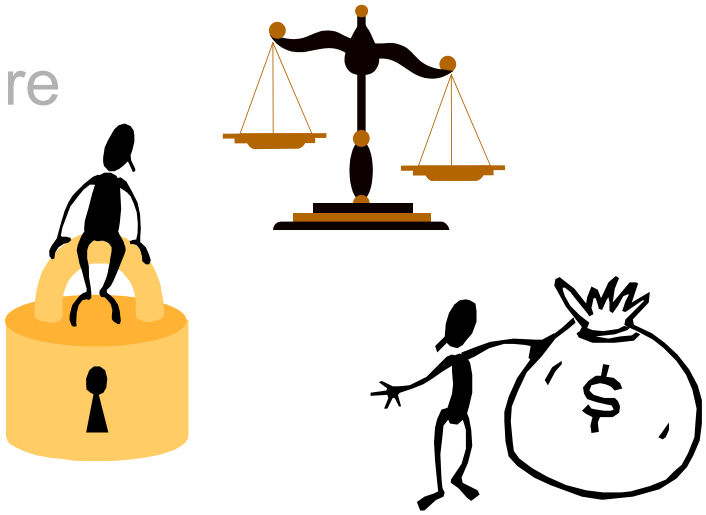
Any Questions?





Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication



What is CNP?

- Most of what has been discussed up to now assumes that the Card (and Cardholder) are physically present at a Merchant/Acquirer terminal
- Another class of transactions exist where such an assumption is not valid – such transactions are termed Cardholder Not Present (CNP transactions)
- CNP includes in particular e-Commerce transactions, but also Mail Order/Telephone Order (MO/TO)

What is the difference?

- In general, the rules mean that merchants and Acquirers get more protection in Cardholder Present transactions than they do in CNP transactions
- More protection ⇨ less risk ⇨ lower costs
- It is also the case that, less protection ⇨ more risk ⇨ higher costs
- The higher costs are mostly due to “chargebacks” that occur when a cardholder disputes an item on their bill.
- They allow an Issuer to reverse a transaction and send it back to the acquirer/merchant – effectively they don’t get paid.

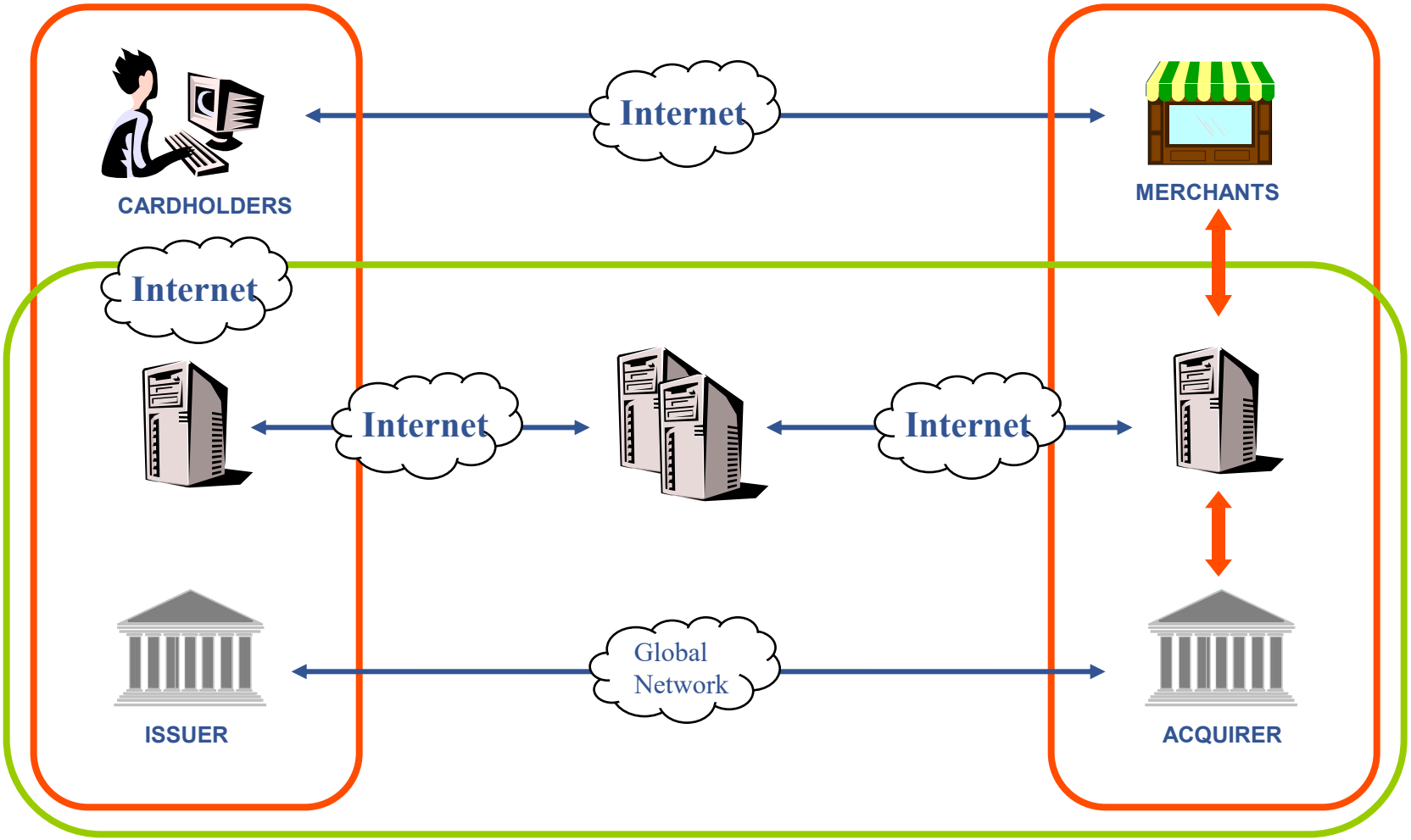
3D-Secure

- **3-D Secure** as an EMVCo specification came about in 2001 as a protocol to improve the security of Internet transactions and allow the payment systems to re-balance the rules.
- **3-D Secure** version 2 was published by EMVCo at the end of 2017. This aims to improve the cardholder experience by supporting “frictionless” transactions where the cardholders do not have to actively authenticate themselves.

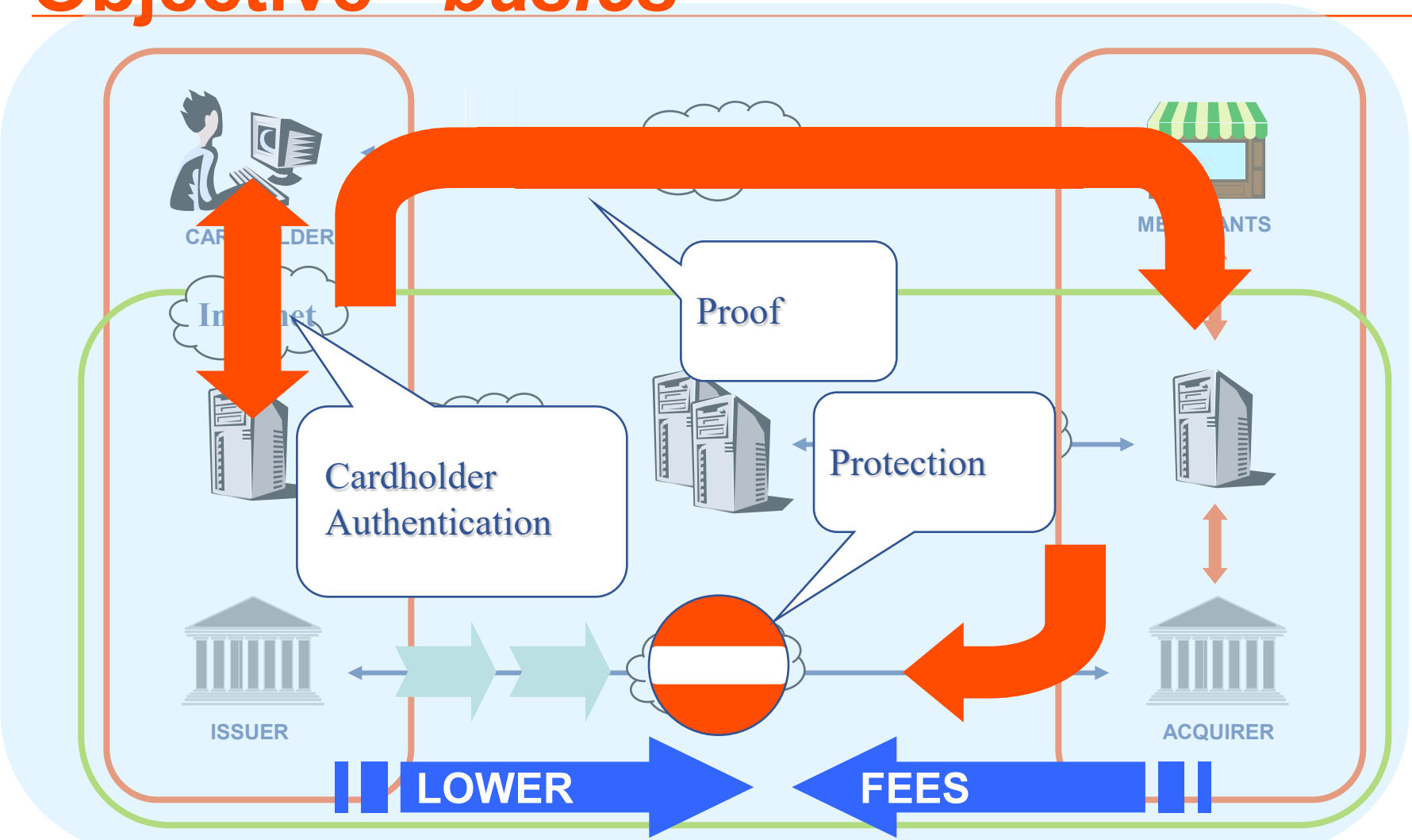
“Current” Version of 3D Secure

Feature	Description
Latest Version	3D Secure 2.3.1
Multi-Channel Authentication	Supports authentication across multiple devices and channels.
Enhanced Data Exchange	Improved data sharing between merchants and issuers for better risk assessment.
Streamlined Authentication	More efficient authentication workflows, reducing friction for consumers.

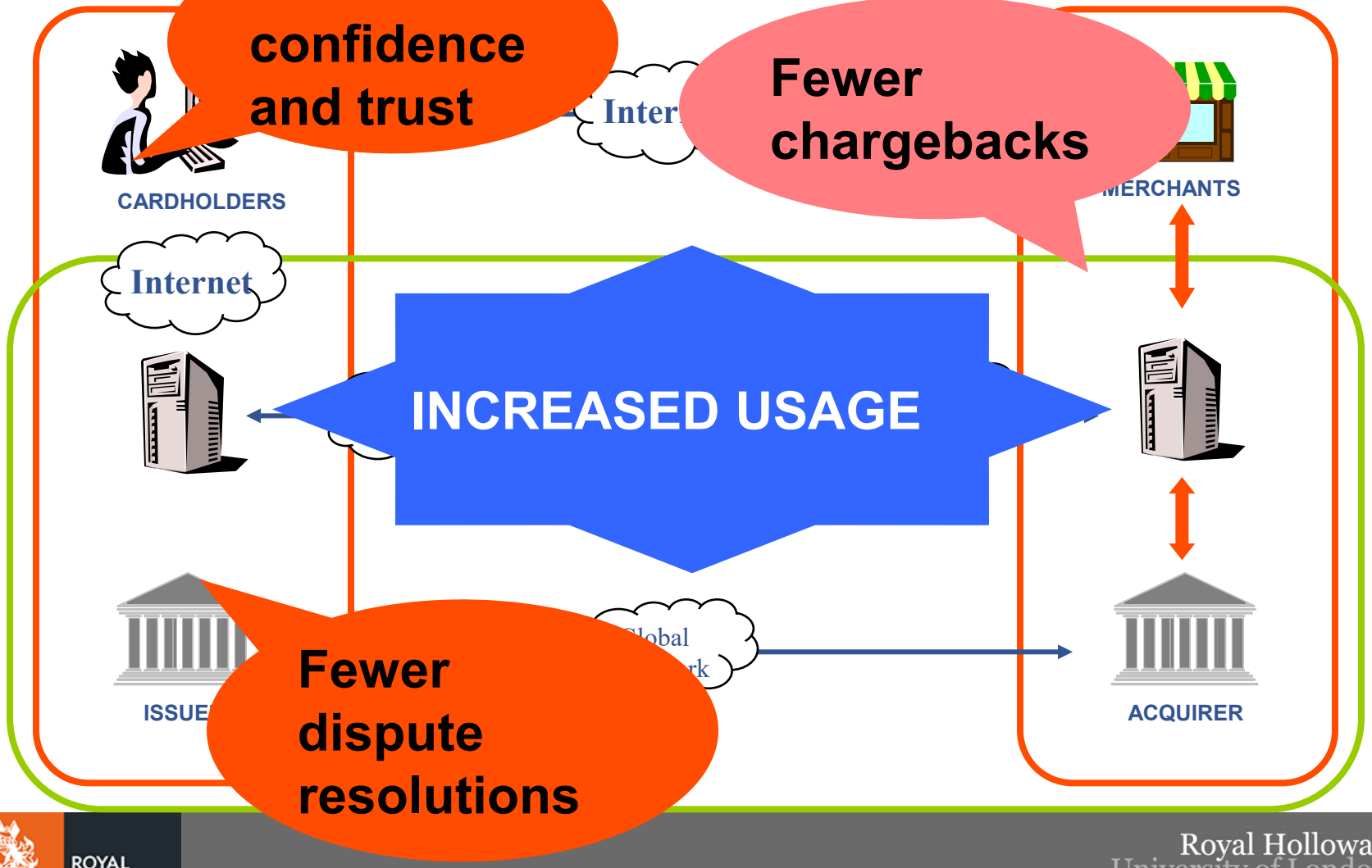
The Three Domains



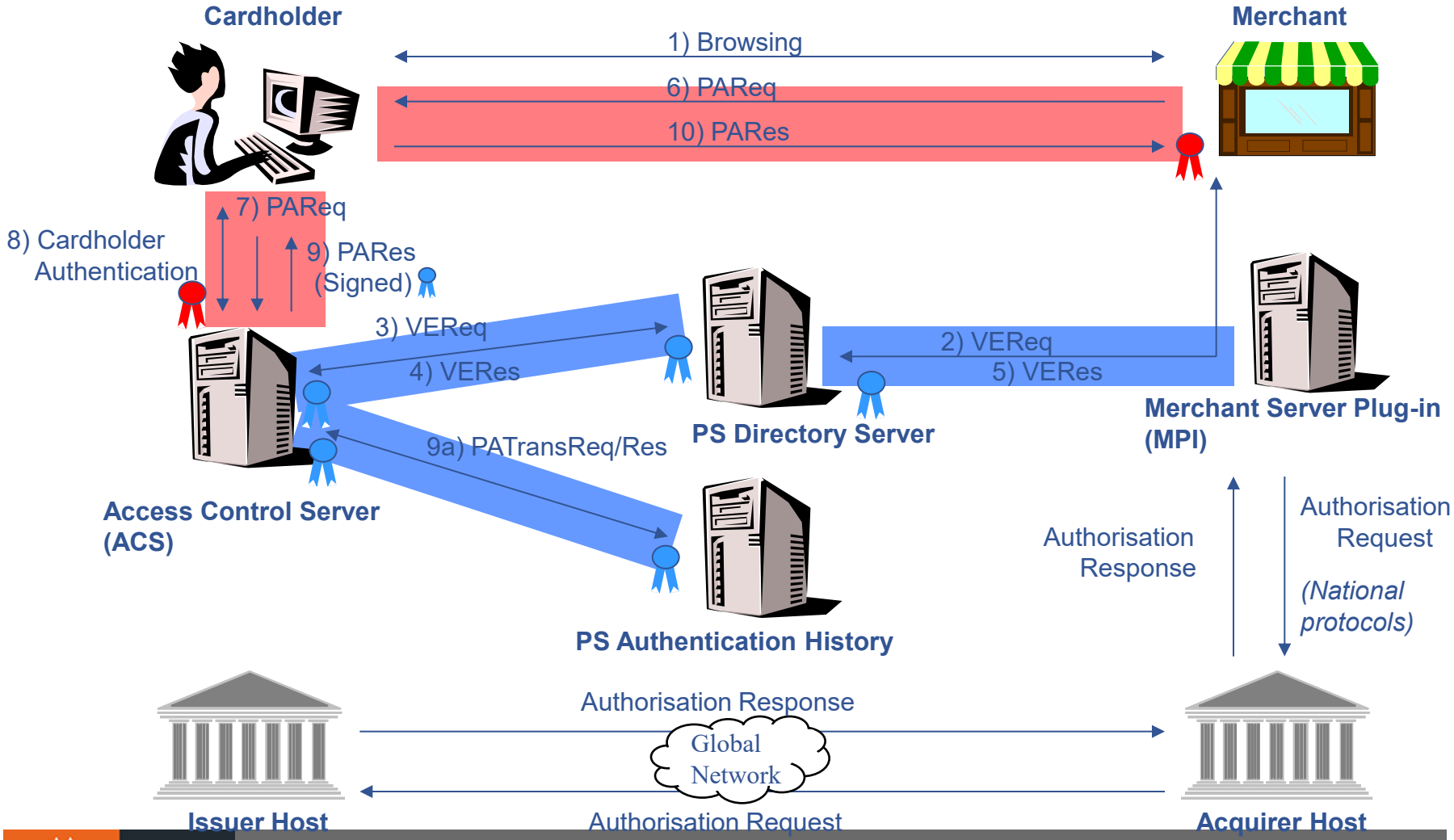
Objective - *basics*



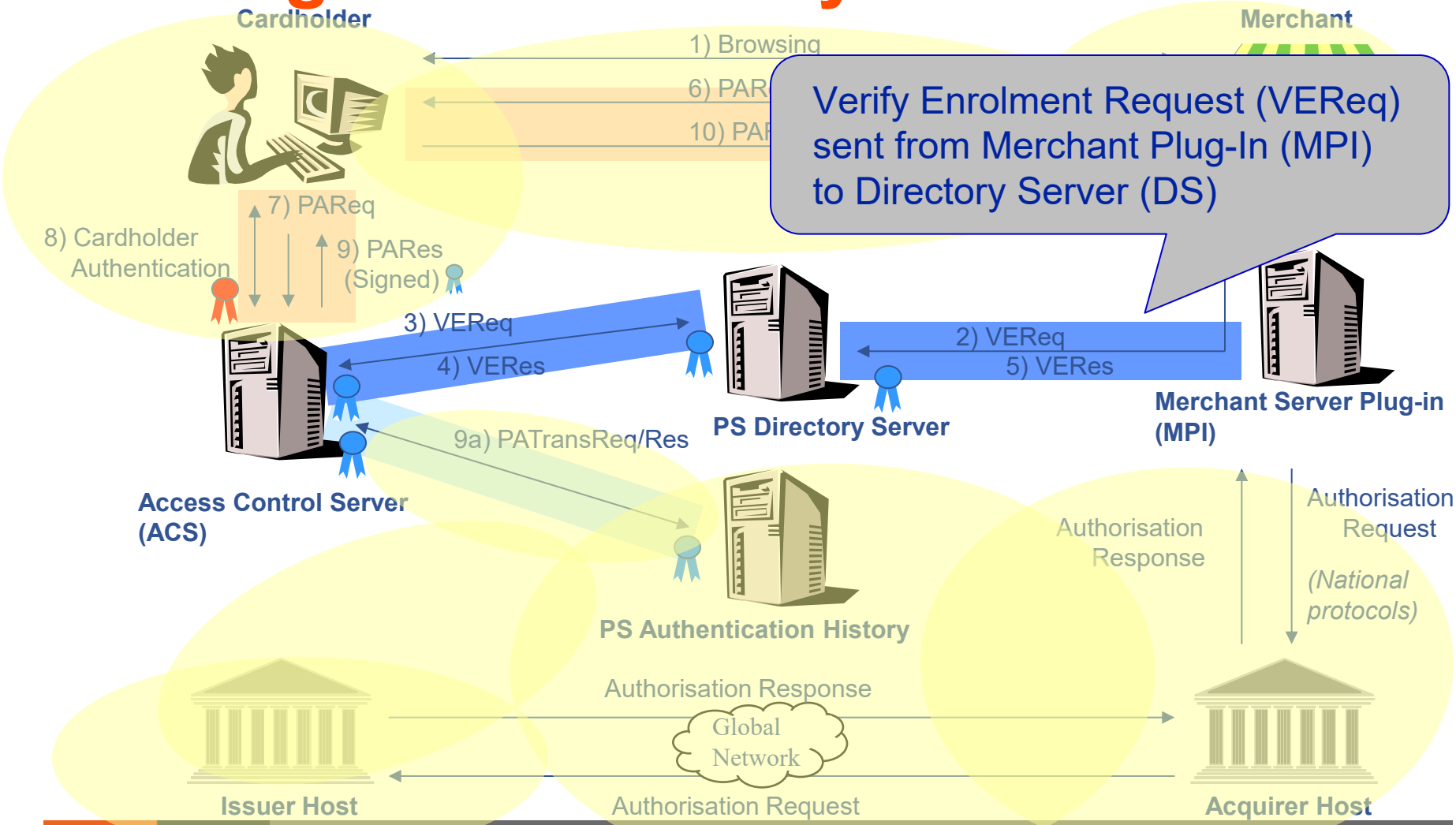
Objective - *benefits*



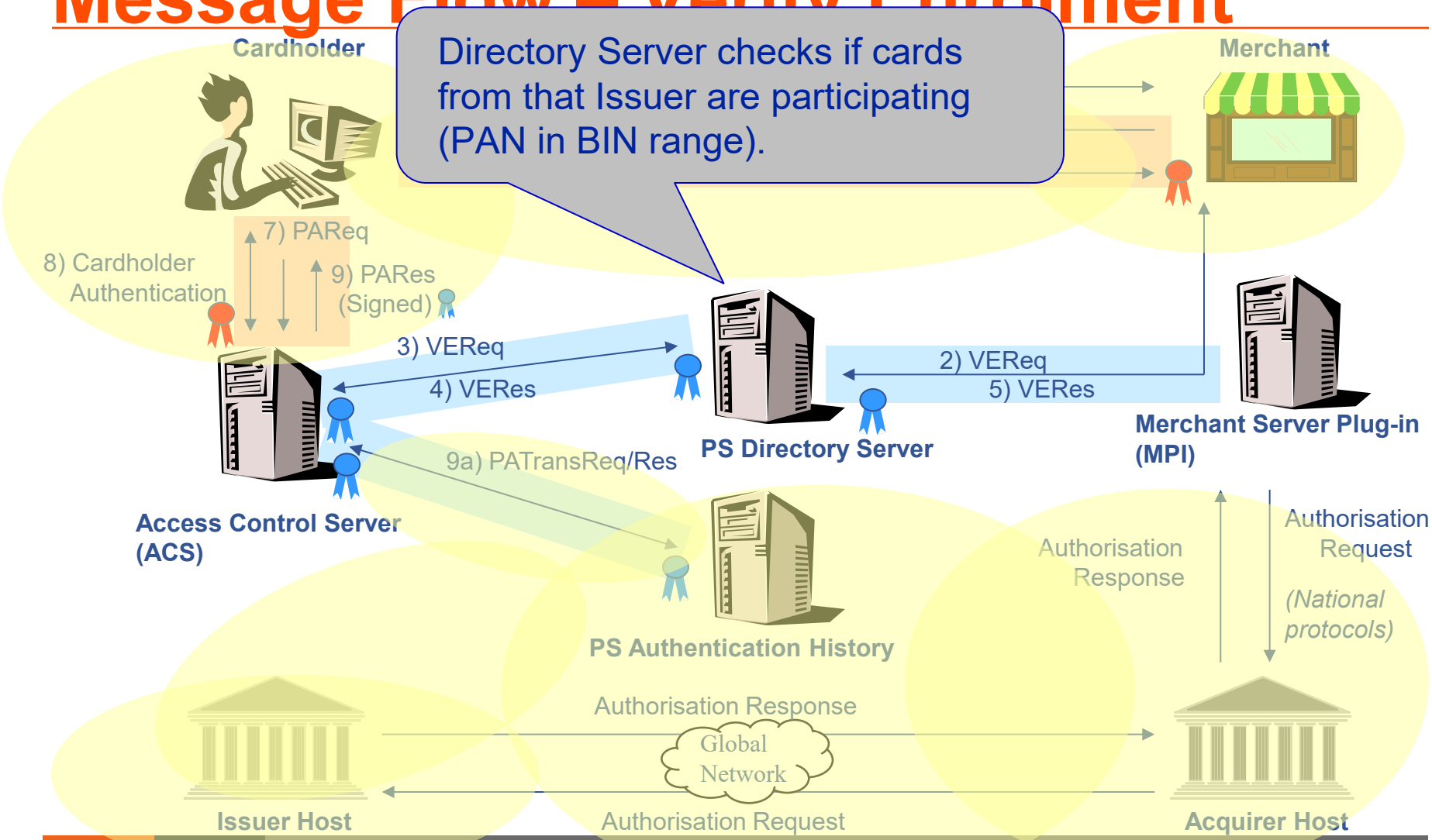
Implementation



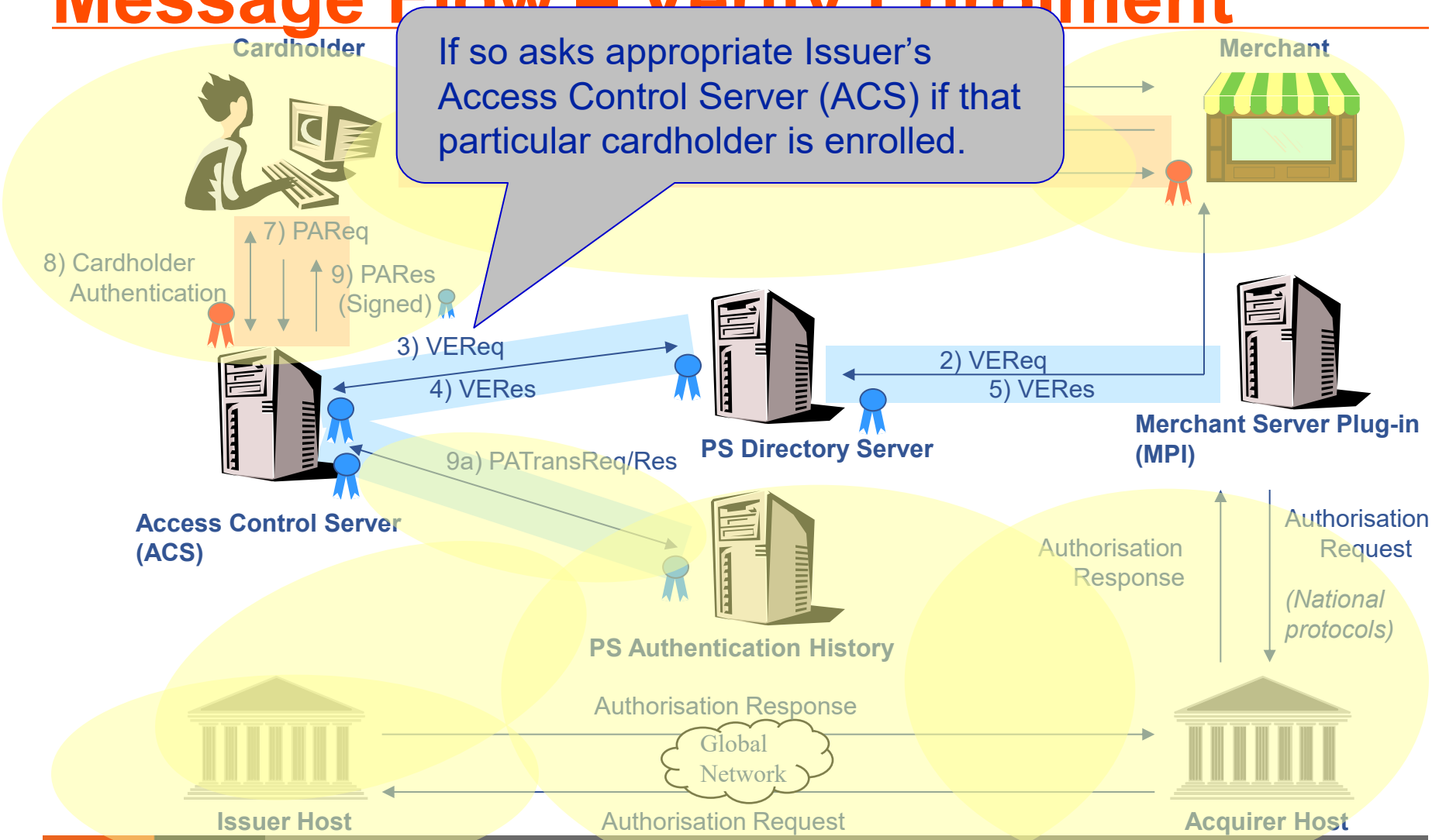
Message Flow – Verify Enrolment



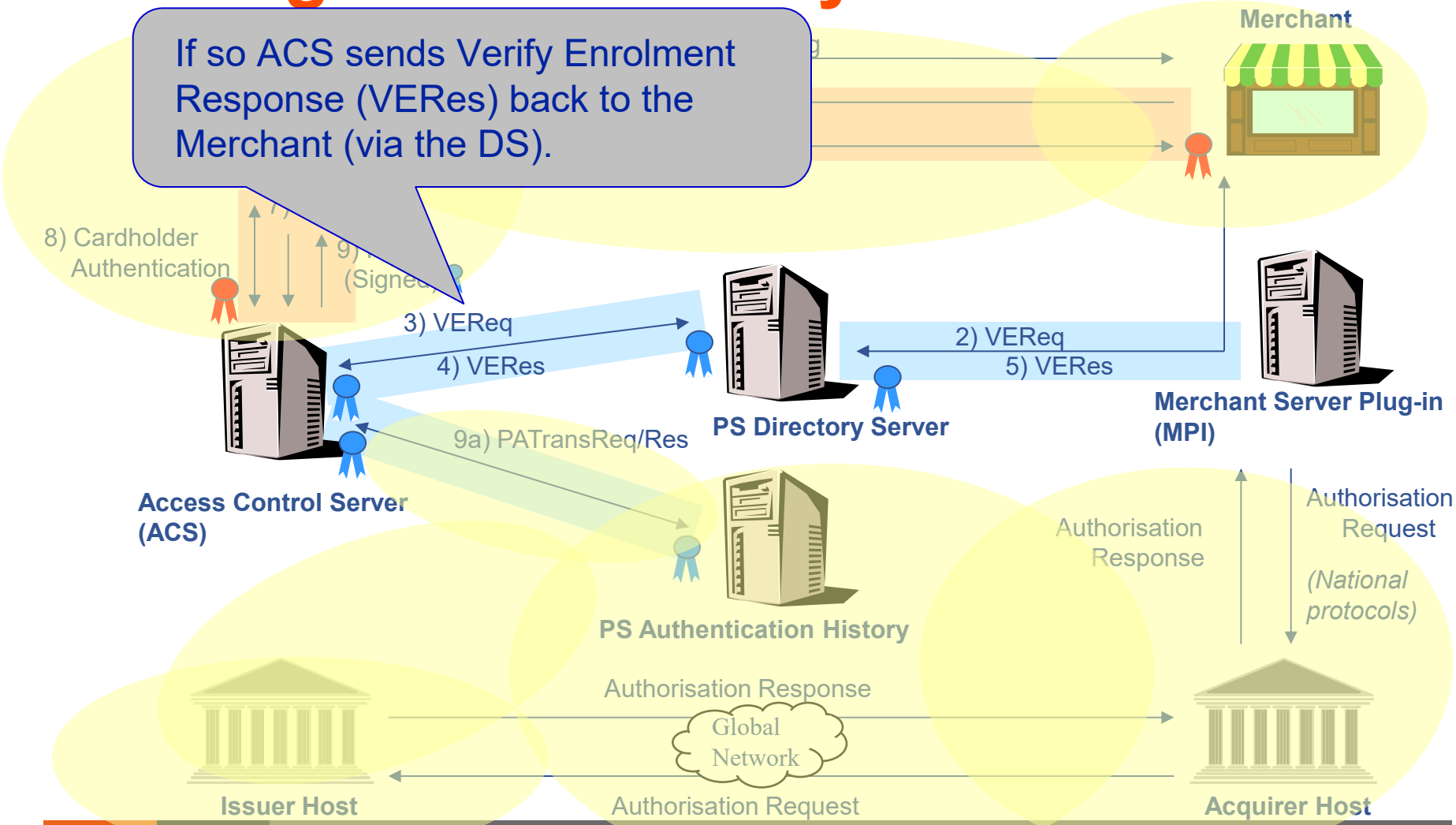
Message Flow – Verify Enrolment



Message Flow – Verify Enrolment

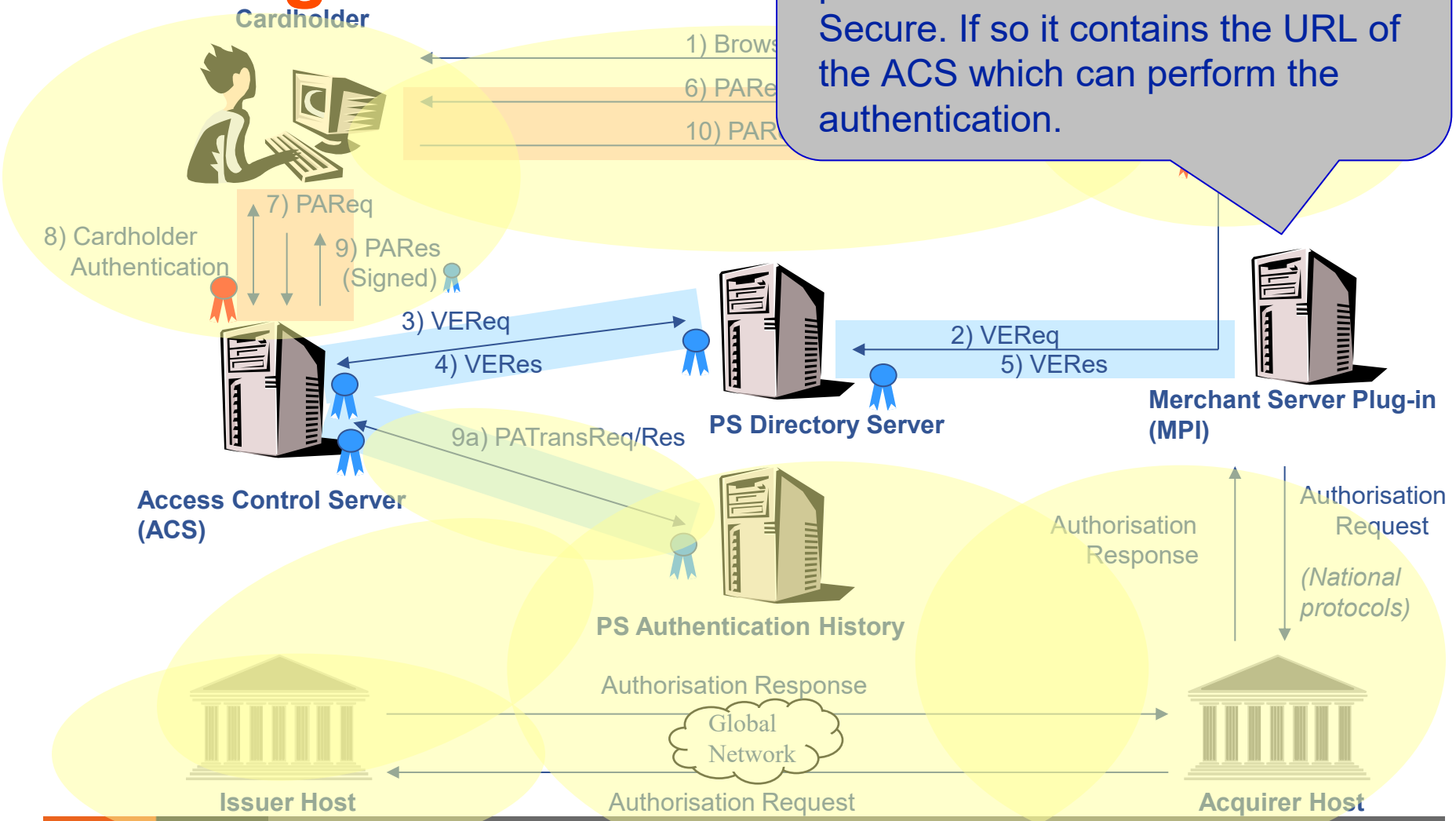


Message Flow – Verify Enrolment

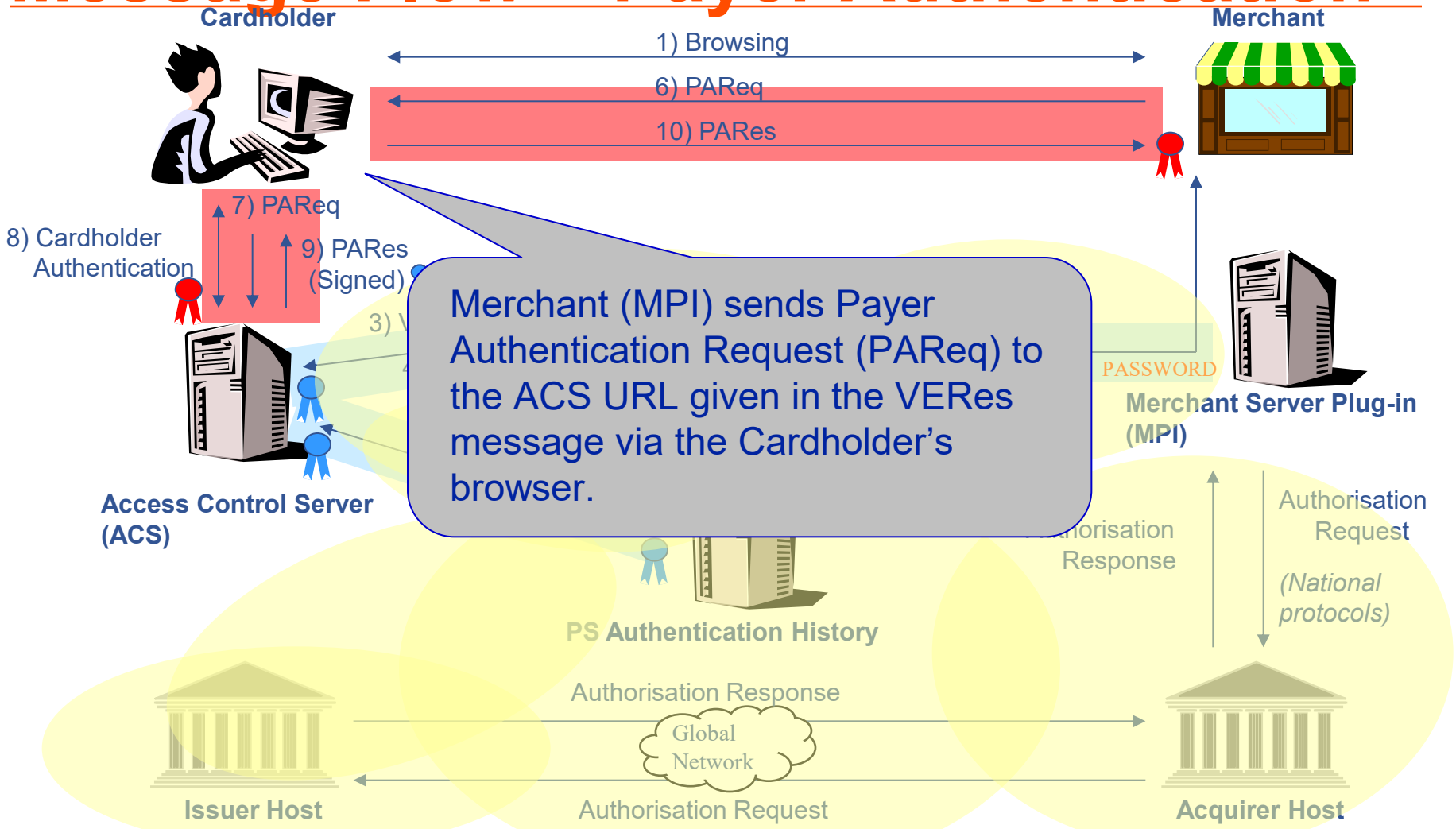


Message Flow – Veri

Result is a message indicating if a particular card is enrolled for 3D-Secure. If so it contains the URL of the ACS which can perform the authentication.

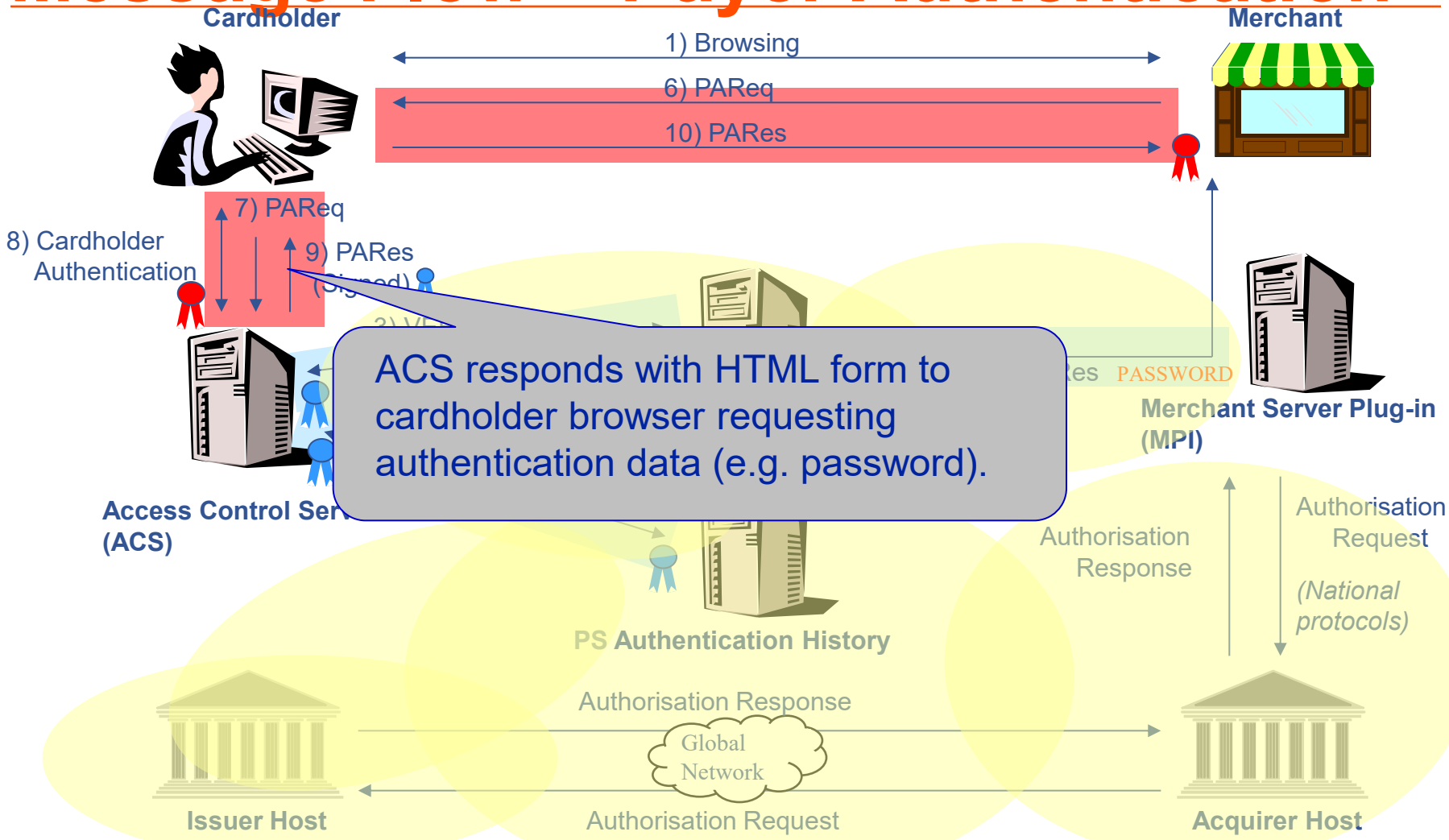


Message Flow – Payer Authentication



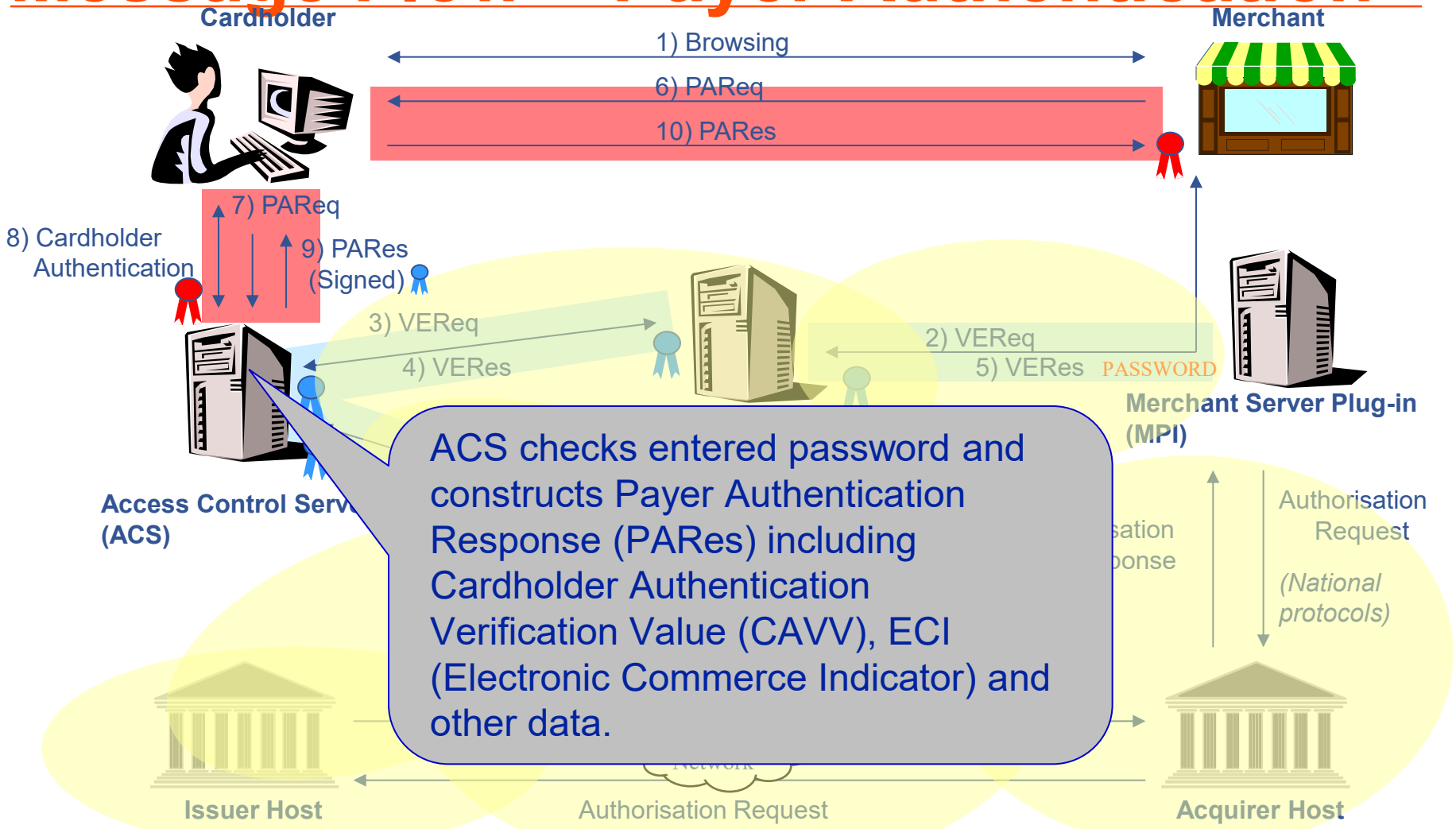
Merchant (MPI) sends Payer Authentication Request (PAReq) to the ACS URL given in the VERes message via the Cardholder's browser.

Message Flow – Payer Authentication



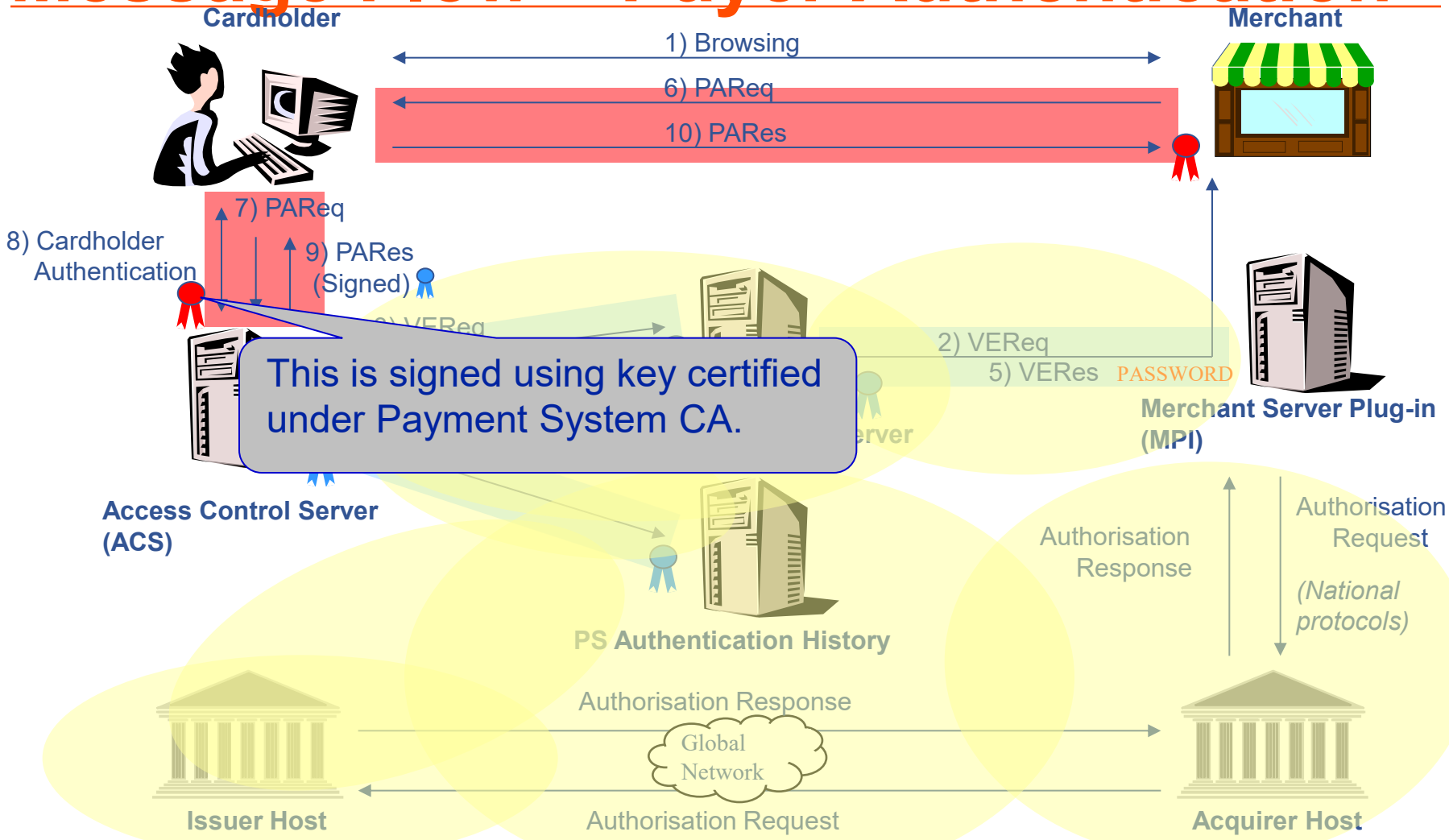
ACS responds with HTML form to cardholder browser requesting authentication data (e.g. password).

Message Flow – Payer Authentication



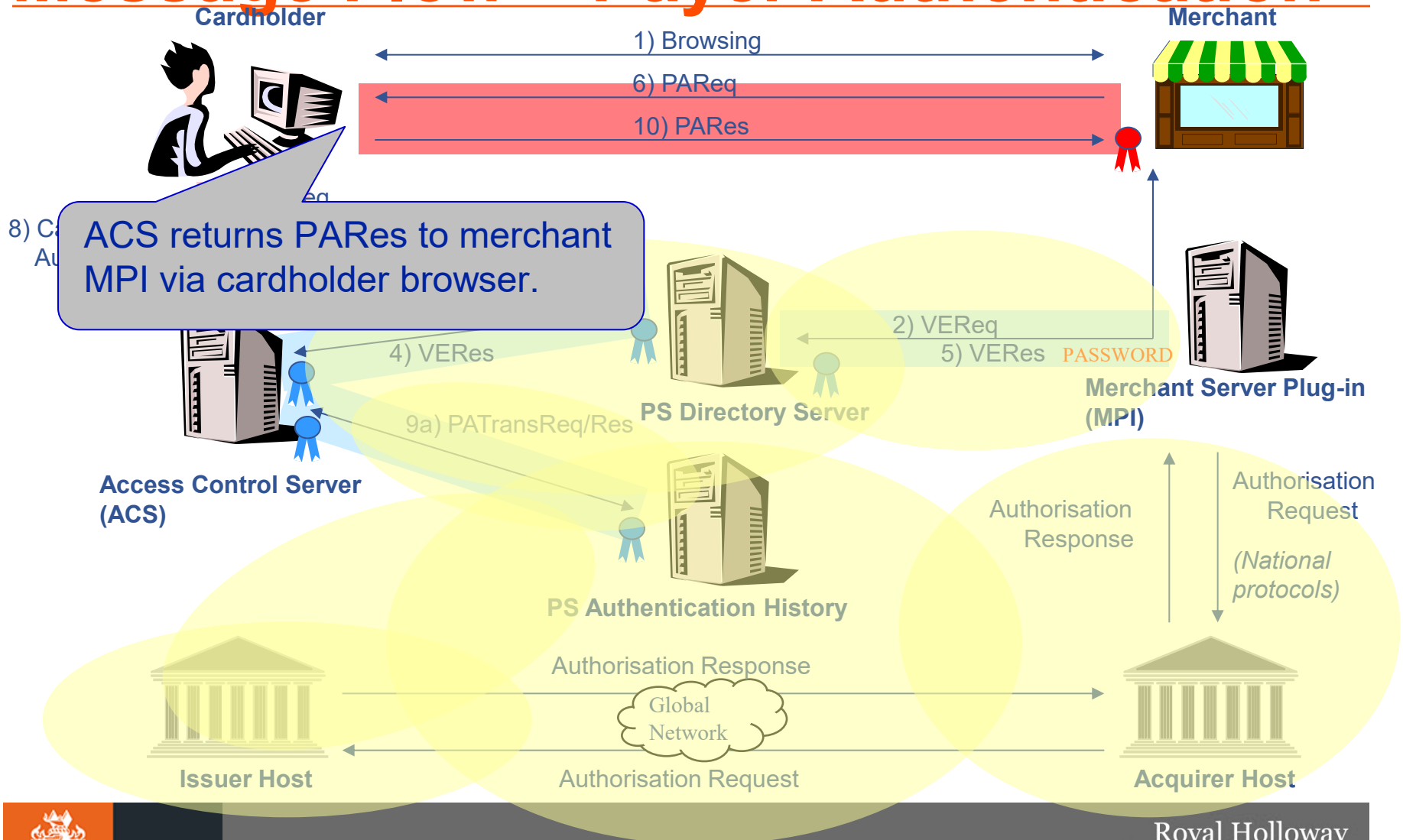
ACS checks entered password and constructs Payer Authentication Response (PARes) including Cardholder Authentication Verification Value (CAVV), ECI (Electronic Commerce Indicator) and other data.

Message Flow – Payer Authentication

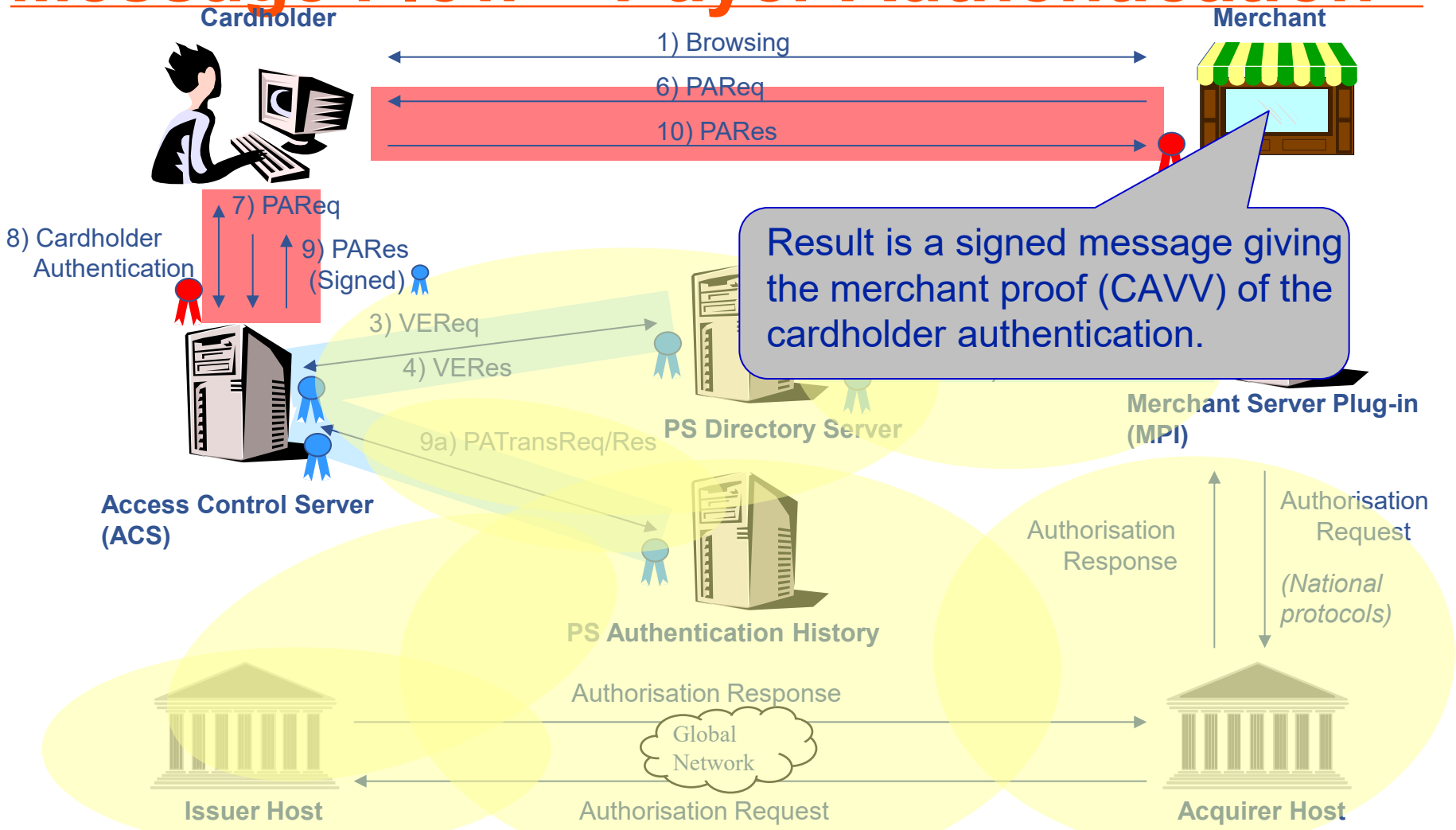


This is signed using key certified under Payment System CA.

Message Flow – Payer Authentication



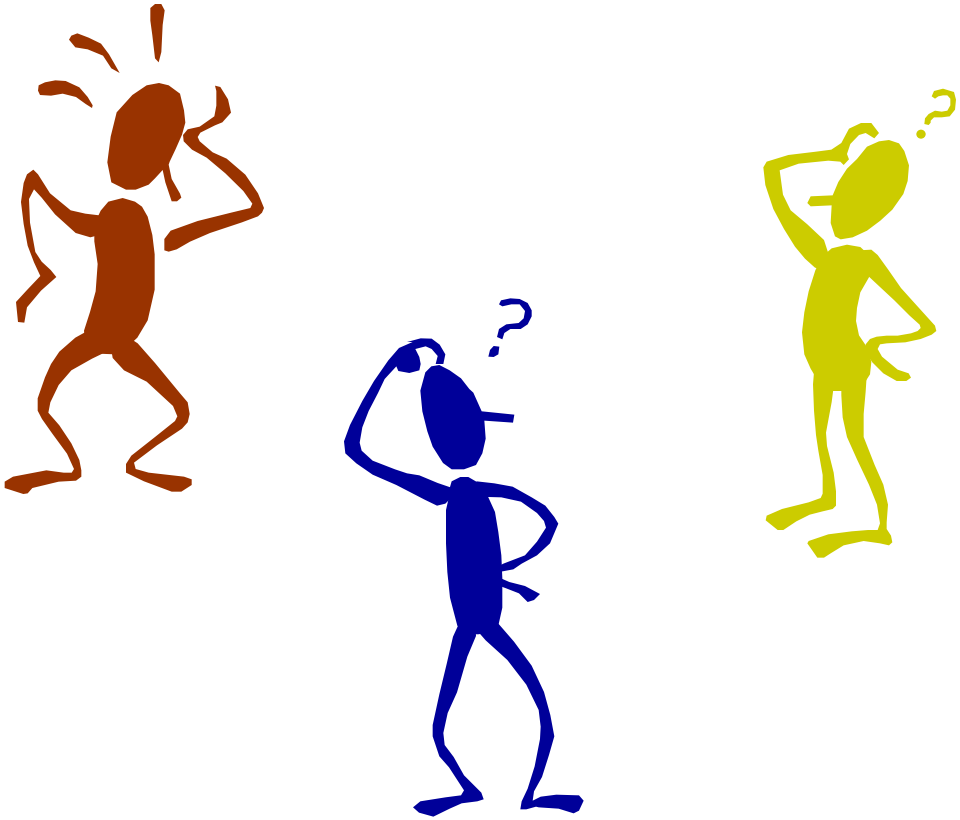
Message Flow – Payer Authentication



Summary of Evidence

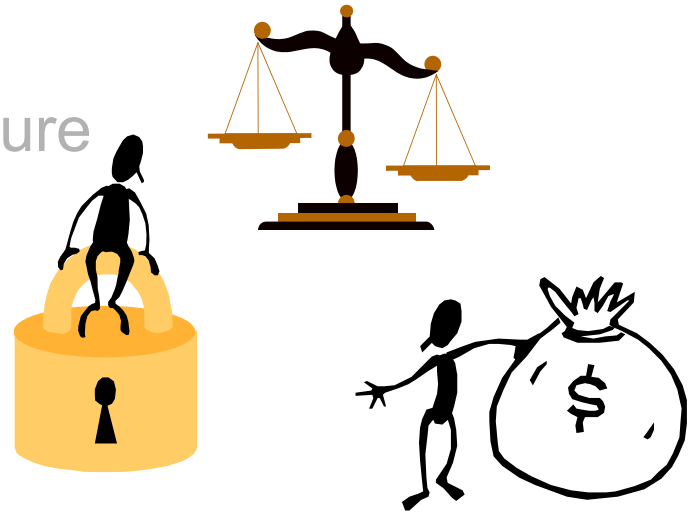
- Issuer – obtains cardholder authentication data from cardholder (password, token, etc.).
- Issuer – submits copy of the PARes (and other data) to the authentication history server (step 9a).
- Merchant – obtains a signed message (PARes) from issuer which dictates the action to be undertaken (proceed or not with transaction).
- Merchant – submits transaction for authorisation with the knowledge that the issuer has accepted the liability of this transaction with regards to cardholder identification. Once authorised, there is a liability shift from acquirer/merchant to issuer (similar to cardholder present situation).

Any Questions?



Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication



Contactless

Cardholder message:

- "Wave and Pay for transactions below ~~£20~~ ~~£30~~ ~~50~~ 100 where you see the contactless indicator . . ."
- ". . . from time to time you may be asked to revert to contact Chip and PIN for your security"

Behind-the-scenes:

- Offline DDA/CDA style authentication
- 'pre-authorised' offline contactless counter in chip
- Reset every time cardholder performs a chip and PIN transaction
- If counter runs down, chip forces contact transaction
- Issuer risk limited to counter maximum

In conjunction with transport . . .

Credit/Debit

- Badge in/out each trip.
- Entry → The card is authenticated with offline mechanism
- Exit → The card is authenticated with offline mechanism
- Back-office system sorts it out and submits one transaction at the end of the day.
- Fares capped at price of “travel card”.

In conjunction with transport . . .

Any EMV contactless card (of major brands.

On London buses from 2013.

- 100,000s journeys a day

On the tube from Oct 2014.

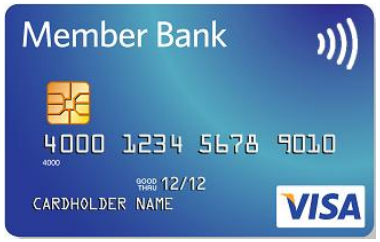
- First million after just 9 days

Now beginning to spread outside of London.

- Surface rail and other cities

Indicators and Specs

Contactless indicator on cards



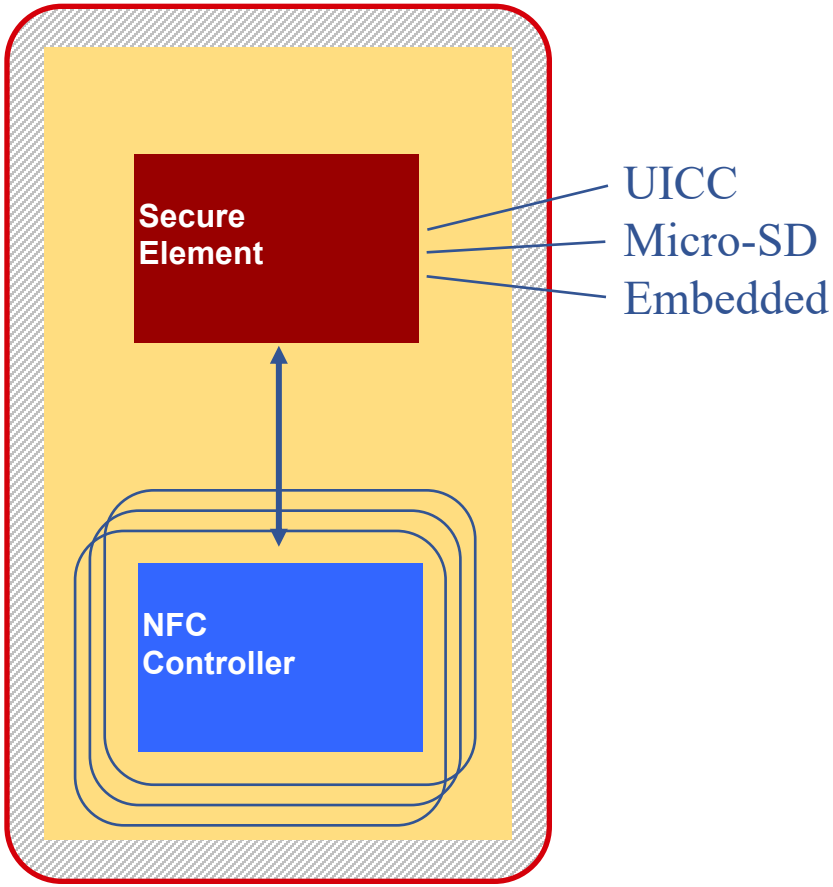
Point of Sale indicator agreed between Visa, MasterCard and American Express

EMV **Contactless Communication Protocol** and **Entry Point** specs allow common acceptance points

Gone Mobile

- Mobile use based on Near Field Communication (NFC) technology.
- Based on ISO 14443 – same as EMV contactless
- Allows handsets to work like contactless cards

Mobile Handsets and Secure Elements (SEs)

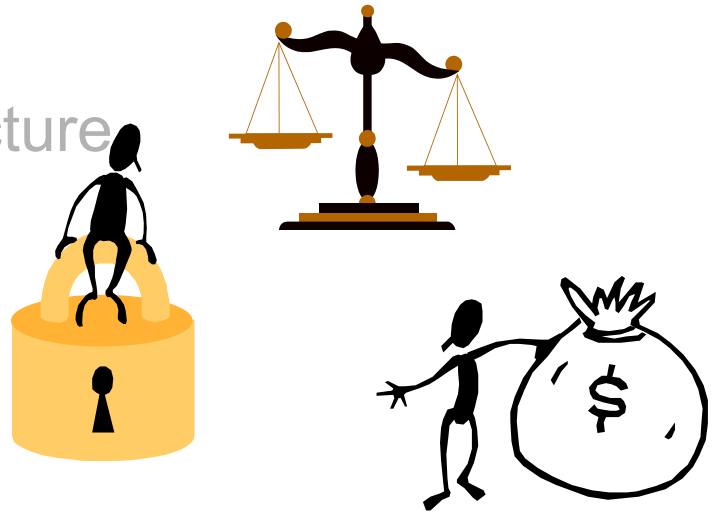


More Mobile

- Mobile handsets as mobile wallets
  - User interface allows consumer to control and select from a range of payment applications
  - Multiple brands supported in same wallet
  - Authentication on the phone allows for higher value transactions.
- Mobile POS
  - “Add-on” readers & PIN pads allow small merchants to use their mobiles for card transactions
  - Network connection is mobile data link
  - User has contract with “agent” that acts as link to acquirer
- Mobile Apps for e-commerce
  - Users download apps for favourite merchants. Payment options and authentication largely happen transparently

Outline

- A Little History
- Payment Systems – the Big Picture
- Mag-stripe world
- EMV Chip
  - Key Management
- e-Commerce 3-D Secure
- Contactless & Mobile
- Token Authentication



What is it?

Passcode Authentication (otherwise known as Token Authentication or Token Based Authentication)

- Two factor authentication
  - Something you own – EMV chip card
  - Something you know – PIN
  - Stronger than static passwords
  - Good against phishing
- Can include other features
  - Use of random challenge
  - Input of amount and currency
  - Signing of external data

How Does it Work?

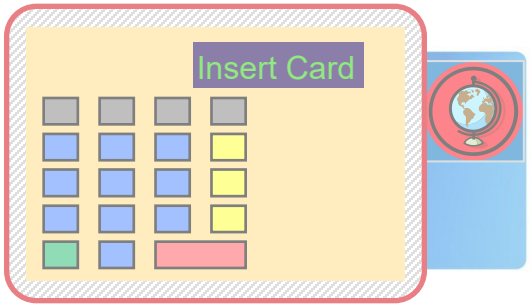
- Cardholder uses banking/payment card and small unconnected handheld reader to produce a “token” or “signature”.
- Based on EMV cryptogram.
- One-Time Passcode - different for each transaction.

  OR

- Challenge/Response – includes random challenge.

Basic Operation

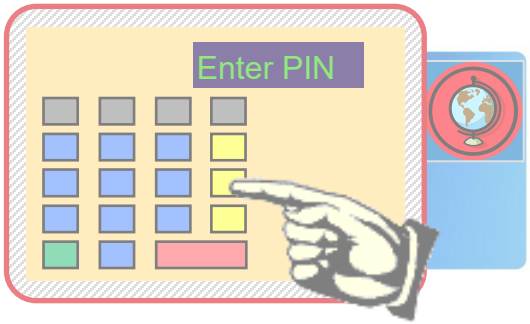
1



Insert Card

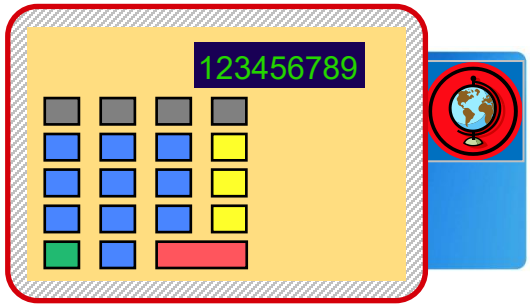
Challenge

2



Enter PIN

3



Transfer Passcode

Passcode Authentication (EMV Token / CAP)

- Problem solved: secure user authentication without continuous online connectivity
- How it works (embedded perspective):
  - EMV card acts as a secure cryptographic token
  - User enters PIN to activate the card
  - Card generates a one-time cryptographic response based on a challenge or transaction data
- Key properties:
  - One-time, non-replayable passcodes; secrets never leave the card
  - Works offline and is resistant to phishing and malware

Tokenisation

- Tokenization refers
  - to replacing sensitive data (e.g. card numbers) with a unique identifier called a token.
- Token:
  - A non-sensitive representation of real payment data, cannot be used outside the specific transaction.
- In EMV:
  - tokenization is used to ensure actual card details are never exposed or transmitted during payment transactions.

Future of Payments…

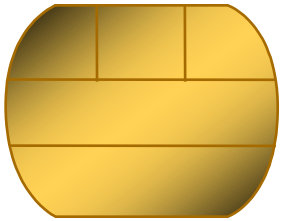
- Build a future where we trust AI agents to shop and buy for us
- Visa Agent APIs combine tokenization, authentication and transaction controls
- The landscape…

https://corporate.visa.com/content/dam/VCOM/corporate/documents/about-visa-factsheet.pdf

What This Lecture Did Not Cover

- This lecture focused on architecture, trust, and system design
- It intentionally did not cover:
  - EMV vulnerabilities and real-world attacks
  - Side-channel and fault injection techniques
  - Terminal compromise and malware
  - Protocol downgrade and fallback abuse
  - AI in Payments
- Some of these topics are addressed in a dedicated follow-on lecture
  - Security for Trustworthy Embedded Systems
  - AI in Trustworthy Embedded Systems

Special thanks to: *DAVID MAIN*



Copyrighted Images belong to their designers, e.g. ORGA, G&D, TNO, Gemplus/Gemalto, and others.

Thank you for your attention…

Any Questions?